

CIS Everpure FlashArray Purity 6.9.x Benchmark

v1.0.0 - 08-04-2026

Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is **NEVER** acceptable to host a CIS Benchmark in **ANY** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use	1
Table of Contents	2
Overview	5
Important Usage Information	5
Key Stakeholders	5
Apply the Correct Version of a Benchmark	6
Exceptions	6
Remediation	7
Summary	7
Target Technology Details	8
Intended Audience.....	8
Consensus Guidance	9
Typographical Conventions.....	10
Recommendation Definitions.....	11
Title.....	11
Assessment Status.....	11
Automated	11
Manual.....	11
Profile	11
Description.....	11
Rationale Statement	11
Impact Statement.....	12
Audit Procedure.....	12
Remediation Procedure.....	12
Default Value.....	12
References	12
CIS Critical Security Controls® (CIS Controls®).....	12
Additional Information.....	12
Profile Definitions	13
Acknowledgements	14
Recommendations	16
1 Identity and Access Management (IAM).....	16
1.1 Ensure a management SAML SSO configuration is created and enabled (Manual)	17
1.2 Ensure a management LDAP/Active Directory service is configured and enabled with at least one group mapped (Manual).....	21

1.3 Ensure only authorized local administrative accounts exist and a local emergency-access account is retained (Manual)	25
1.4 Ensure administrators and directory groups are granted least-privilege roles via management access policies (Manual)	28
1.5 Ensure SSH key-based authentication is configured for CLI access, preferably sourced from LDAP (Manual)	33
1.6 Ensure brute-force lockout is set to 3 attempts with a lockout duration of at least 1 hour (Automated)	36
1.7 Ensure the password policy enforces 8+ characters, 3+ character groups, and username and dictionary checks (Automated)	39
1.8 Ensure OAuth API clients use least-privilege access policies and access-token TTLs of 60 minutes or less (Manual).....	42
1.9 Ensure static REST API tokens are used only when necessary and configured to expire periodically (Manual).....	46
1.10 Ensure administrative audit logs are forwarded to remote syslog or monitored via the REST API (Manual)	50
1.11 Ensure administrative session logs are forwarded to remote syslog or monitored via the REST API (Manual)	54
1.12 Ensure system alerts are actively monitored via remote syslog or email alert watchers (Manual).....	58
1.13 Ensure at least one alert watcher is configured to receive alerts of all severities (Automated)	62
1.14 Ensure at least one remote management syslog server is configured (Automated).....	66
2 Environmental.....	68
2.1 Ensure array TLS certificates are CA-signed, adequately sized, and rotated at least every 90 days (Manual)	69
2.2 Ensure SAML SSO uses HTTPS with encrypted assertions and signed requests (Manual)	73
2.3 Ensure Active Directory accounts are configured to require TLS (Manual)	77
2.4 Ensure LDAP directory services use LDAPS with a configured CA root of trust (Automated)	80
2.5 Ensure syslog servers use TLS with a configured CA root of trust (Automated)	83
2.6 Ensure the SMTP relay host is configured with STARTTLS encryption and authentication (Automated)	86
2.7 Ensure SNMP, if enabled, uses SNMPv3 with SHA authentication and AES privacy (Automated)	89
2.8 Ensure at least 3 NTP servers and an NTP symmetric key are configured (Automated) ..	93
2.9 Ensure product diagnostic tests for environmental integrations are run periodically (Manual).....	96
3 Protocol.....	99
3.1 Ensure NFS export policies restrict client access and enforce secure authentication (no wildcards, root squash, no sys auth) (Automated)	100
3.2 Ensure SMB client policies require encryption, restrict client access, and disable anonymous access (Automated)	104
3.3 Ensure native Active Directory integration is used for NFS and SMB identity and authentication (Manual)	108
3.4 Ensure a hard-limit quota policy is enforced on the root managed directory of every file system (Automated).....	111
3.5 Ensure space consumption and performance are monitored for anomalies (Manual).....	114
3.6 Ensure SMB audit policies with syslog and file log targets are attached to production file systems (Manual).....	117
4 Data Protection	121
4.1 Ensure manual eradication is disabled and the eradication delay is at least 8 days for production data (Automated)	122

4.2 Ensure production volumes and hosts are protected by ratcheted (SafeMode) protection groups with daily snapshots (Manual)	126
4.3 Ensure an enabled snapshot policy taking at least one daily snapshot is attached to every directory (Automated)	131
4.4 Ensure default protection is configured at the array level and for every pod (Automated)	135
4.5 Ensure at least one encrypted array connection is configured for replication (Manual)...	139
4.6 Ensure a snapshot offload target using HTTPS is configured when no array connection is available (Manual).....	143
4.7 Ensure the health of array connections and offload targets is continuously monitored (Manual).....	147

Appendix: Summary Table	151
Appendix: CIS Controls v8 IG 1 Mapped Recommendations	155
Appendix: CIS Controls v8 IG 2 Mapped Recommendations	157
Appendix: CIS Controls v8 IG 3 Mapped Recommendations	159
Appendix: CIS Controls v8 Unmapped Recommendations.....	162
Appendix: Change History	163

Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

Important Usage Information

All Benchmarks are available free for non-commercial use from the [CIS Website](#). They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- [CIS Configuration Assessment Tool \(CIS-CAT® Pro Assessor\)](#)
- [CIS Benchmarks™ Certified 3rd Party Tooling](#)

These tools make the hardening process much more scalable for large numbers of systems and applications.

NOTE: Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that **ALL** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.
- **Use the most recent version of a Benchmark:** This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

Remediation

CIS has developed [Build Kits](#) for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
 - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
 - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
 - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
 - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
 - When the initial deployment above is completed successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

NOTE: As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the [CIS Website](#). All other formats of the CIS Benchmarks™ (MS Word, Excel, and [Build Kits](#)) are available for CIS [SecureSuite®](#) members.

CIS-CAT® Pro is also available to CIS [SecureSuite®](#) members.

Target Technology Details

This document provides prescriptive guidance for establishing a secure configuration posture for Everpure FlashArray systems running Purity version 6.9.x.

The guidance broadly assumes that operations are being performed by an administrator with appropriate privileges. Operations performed without sufficient permissions may produce unexpected results or fail to make the intended changes to the system.

Certain configuration guidance within this document may necessitate contacting Everpure Support at support@everpuredata.com. For inquiries, commentary, or suggestions regarding enhancements to this guide, please direct correspondence to feedback@cisecurity.org.

Intended Audience

This benchmark is primarily intended for Everpure customers, specifically storage administrators, security specialists, auditors, help desk, and platform deployment personnel who are responsible for developing, deploying, assessing, or securing solutions that incorporate Everpure FlashArray within their environments.

Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
<code>Stylized Monospace font</code>	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
<code>Monospace font</code>	Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.
<code><Monospace font in brackets></code>	Text set in angle brackets denote a variable requiring substitution for a real value.
<i>Italic font</i>	Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.
Bold font	Additional information or caveats things like Notes , Warnings , or Cautions (usually just the word itself and the rest of the text normal).

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) "5.1 - Establish Secure Configurations" and (v8) "4.1 - Establish and Maintain a Secure Configuration Process" so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

Items in this profile intend to:

- be practical and prudent;
- provide a clear security benefit; and
- not inhibit the utility of the technology beyond acceptable means.

- **Level 2**

This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is paramount.
- acts as defense in depth measure.
- may negatively inhibit the utility or performance of the technology.

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

This benchmark is the result of a collaborative effort between Everpure and the Center for Internet Security (CIS). This benchmark stands as a testament to the value that a community of users, vendors, and subject matter experts can deliver through consensus-driven collaboration.

Authors

- Dennis Samuel
- Azaria Zornberg

Contributors

- Jeroen Habraken-Parkes
- Jason Heidenreich
- Rohith Sajja
- Sakthi Rangaraju
- Jon Ludford
- Brian Crandall
- Robert Bartlett

Editor

- Phil White, Center for Internet Security

Recommendations

1 Identity and Access Management (IAM)

This section covers the configuration of user accounts, authentication mechanisms, and access rights. It includes controls for securing local administrative users, integrating with external identity providers (SAML, LDAP), and enforcing Role-Based Access Control (RBAC) to ensure that only authorized individuals can access the system.

1.1 Ensure a management SAML SSO configuration is created and enabled (Manual)

Profile Applicability:

- Level 1

Description:

Purity can be integrated with an external identity provider (IDP) that supports SAML. This allows for single-sign-on (SSO) functionality in the Everpure Web UI, with user provisioning, authentication, and authorization being controlled by the IDP.

Everpure recommends that you create and enable a management SAML configuration.

Rationale:

SAML provides mechanisms for more secure authentication to FlashArray. IDPs can provide assertions about user information, which are digitally signed, allowing FlashArray, acting as the Service Provider (SP), to gather user details in a trusted manner for user authentication and authorization.

This allows authentication to be centralized with an IDP, allowing for the IDP to enforce strong central controls, such as multi-factor authentication, device trust mechanisms, and other security capabilities provided by your IDP.

IDPs can directly provide user authorization information to Purity systems using a custom "purity_roles" SAML claim. Alternatively, the array can be configured to map authorization information based on groups, allowing a standard SAML group to be used. In either case, it puts the IDP in control of information used to authorize users.

IDP assertions can be optionally encrypted, and FlashArray's authentication assertions can be optionally signed as well, providing additional security controls that may be valuable depending on your environment.

Users who have logged into the Web UI using SAML may also login via SSH using a public key or SSH certificate, and may login via the REST API with an API Token or OAuth JWT, but their authorization must be periodically refreshed via SAML login.

Impact:

Configuring SAML SSO introduces a dependency on IdP availability. If the IdP becomes unreachable, management access via SAML will be unavailable; only local fallback accounts (if retained) will be accessible. Administrators must maintain at least one local emergency access account and ensure IdP high availability. Initial configuration requires coordination between the FlashArray administrator and the IdP administrator to exchange metadata and certificates.

Audit:

To align with the security recommendations, verify that at least one SAML Identity Provider (IdP) is configured, its status is actively enabled, it references the correct IdP URL and verification certificate, and that the configuration successfully passes diagnostic connectivity tests.

From the GUI:

- Navigate to **Settings > Access > Users and Policies** and scroll to the **SAML2 SSO** pane.
- Verify that the **Enabled** status is set to true.
- Review the configured settings (such as **Array URL**, **IdP URL**, and **Metadata URL**) to confirm they reference the correct Identity Provider.
- **Test the configuration:** Click **Test** to open the Test SAML2 SSO Configuration dialog, review the basic test results, and then click **E2E Test** to run the End-to-End test. Verify that the authentication process successfully redirects and returns a Passed status without errors.

From the CLI:

- Run the command `puresso saml2 list` to display configured SAML providers.
- Review the output to confirm that a SAML provider is present and its enabled status is True.
- Run the command `puresso saml2 list --verification-certificate` to view the full verification certificate details and verify the certificate issuer and expiry date.
- **Test the configuration:** Run the command `puresso saml2 test [IDP-NAME]` to verify the array URL correctness, IdP connectivity, directory service correctness, and verification certificate validity.

Remediation:

To align with the security recommendations, configure the array as a Service Provider (SP), exchange metadata or certificates with your Identity Provider, and rigorously test the configuration before enabling SSO.

From the GUI:

- Navigate to **Settings > Access > Users and Policies** and scroll to the **SAML2 SSO** pane.
- Click the **+** (Create SAML2 SSO) icon.
- In the **Name** field, enter a local display name for the SAML2 SSO configuration.
- In the **Array URL** field, enter the FlashArray URL using HTTPS.
- Enter either the **IdP Metadata URL**, or manually enter the **IdP Entity ID**, **IdP URL**, and click **Edit** next to **Verification Certificate** to paste your IdP's PEM-formatted token-signing certificate.
- Click **Test** at the bottom of the window to run a basic configuration test, then click **Save**.
- From the SAML2 SSO pane, click **Test** and then **E2E Test** to run the mandatory End-to-End test, which will redirect you to sign in with your IdP credentials.
- *Warning: Only proceed if the End-to-End test successfully passes, otherwise all array users could be locked out of the GUI.*
- Click the **Configuration edit icon**, slide the **Enabled** toggle to the right (blue), and click **Save**.

From the CLI:

- **Create the SAML provider:** Create the configuration using the `puresso saml2 create` command. You can use an IdP metadata XML file or manually specify the URLs.
- *Command Syntax (Metadata):* `puresso saml2 create --array-url <ARRAY_URL> --idp-metadata-url <IDP_METADATA_URL> <IDP_NAME>.`
- *Command Syntax (Manual):* `puresso saml2 create --array-url <ARRAY_URL> --idp-entity-id <IDP_ENTITY_ID> --idp-url <IDP_URL> - -verification-certificate <IDP_NAME>.` (Note: Purity will prompt interactively for the PEM-formatted verification certificate if the flag is used).
- **Test the configuration:** Run the `puresso saml2 test` command to verify the array URL, IdP connectivity, and certificate correctness.
- **Enable SAML2 SSO:** Once testing passes, enable the configuration.
- *Command Syntax:* `puresso saml2 enable <IDP_NAME>.`

Default Value:

By default, SAML2 SSO is not configured or enabled on the FlashArray. All management authentication strictly uses local accounts or directory services out of the box.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 <u>Centralize Account Management</u> Centralize account management through a directory or identity service.			
v8	6.7 <u>Centralize Access Control</u> Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.			

1.2 Ensure a management LDAP/Active Directory service is configured and enabled with at least one group mapped (Manual)

Profile Applicability:

- Level 1

Description:

If your environment does not support SAML, Purity can be integrated with an external identity provider (IDP) that supports LDAP. This allows for password login functionality in the Everpure Web UI and CLI, with user provisioning, password management, and authorization being controlled by the IDP.

If a SAML configuration does not exist, Everpure recommends that you configure and enable the management LDAP directory service, with at least 1 group granted access to the array.

Rationale:

FlashArray can be configured to communicate with one or more LDAP servers using the LDAP protocol and a service account.

This LDAP communication channel is used to verify user passwords during password-based login, and retrieve information on the groups to which a user belongs for authorization purposes.

This allows account management, authorization information, and passwords to be centralized within an IDP, allowing for the IDP to provision, de-provision, authorize, and de-authorize accounts centrally.

An array can be configured to map authorization information based on directory server groups, and a user will be granted the combination of all roles mapped to groups to which they belong. Nested groups are also supported.

Users who are authorized via LDAP may also login via SSH using a public key or SSH certificates if configured, and may login via the REST API with an API Token or OAuth JWTs if configured, and their authorization will be periodically refreshed from the LDAP server.

Impact:

Directory service integration creates a dependency on the availability and reachability of the LDAP/AD server. If DNS resolution fails or the AD server is unreachable, directory-authenticated administrators will be unable to log in, making local fallback accounts essential. When using LDAPS or LDAP with StartTLS (recommended), a valid server certificate must be maintained to avoid authentication failures.

Audit:

To align with the security recommendations, verify that a Directory Service is configured for array management, role-group mappings are defined to govern authorization, and that the configuration successfully passes diagnostic connectivity tests.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- Locate the **Directory Service** panel and select the **Array Management** view.
- Verify that the **Enabled** status is set to true.
- Review the configuration and verify that the **URIs** (preferably using ldaps://), **Base DN**, and **Bind User** are properly configured.
- Review the **Roles** section to confirm that role-group mappings (Array Admin, Storage Admin, Ops Admin, Read Only) are defined to control authorization.
- **Test the configuration:** Click **Test** in the upper-right corner of the panel to run the directory service diagnostic. Verify that resolving the URIs, binding and querying the tree, and finding the configured groups all return a PASSED status.

From the CLI:

- Run the command `purefs list management` (or `purefs list`) to display the current directory service configuration. Verify the URI, Base DN, and Bind User fields are correct and the service is enabled.
- Run the command `purefs role list` to confirm that role-group mappings are securely defined for array roles.
- **Test the configuration:** Run the command `purefs test` to verify that the array can successfully resolve the URIs, bind to the directory using the credentials, and locate the mapped groups without errors.

Remediation:

To align with the security recommendations, configure the management directory service with your LDAP/AD server parameters, map your directory groups to Purity//FA roles, and rigorously test the connection before enabling it.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- In the **Directory Service** panel, select the **Array Management** button, then click the edit icon.
- Enter your LDAP server **URIs** (using ldaps:// for encrypted connections), **Base DN**, **Bind User**, and **Bind Password**. Click **Save**.
- In the **Roles** section of the panel, click the edit icon. Map your Active Directory/LDAP groups to the corresponding Purity//FA RBAC roles (Array Admin, Storage Admin, Ops Admin, Read Only) by specifying the **Group** (Common Name) and **Group Base** (Organizational Unit). Click **Save**.
- Click **Test** to ensure the URIs resolve, the credentials bind successfully, and the mapped groups are found.
- Once the test passes, click the Configuration edit icon again, toggle **Enabled** to blue (true), and click **Save**.

From the CLI:

- **Configure the directory service:** Set the LDAP URIs, base DN, and bind credentials using the `pureds setattr` command.
- **Command Syntax:** `pureds setattr --uri ldaps://<AD_SERVER>:636 --base-dn <BASE_DN> --bind-user <BIND_USER> --bind-password management`
- *(Note: Purity will prompt interactively for the bind password to securely ingest it).*
- **Configure role-group mappings:** Map your LDAP groups to array roles (e.g., array_admin).
- **Command Syntax:** `pureds role setattr <ROLE> --group <AD_GROUP> --group-base <OU>`
- **Example:** `pureds role setattr array_admin --group pureadmins --group-base OU=Storage,DC=company,DC=com.`
- **Test the configuration:** Run the directory service test to ensure connectivity and valid group configurations.
- **Command Syntax:** `pureds test`
- **Enable the directory service:** Only enable the service after the test successfully passes.
- **Command Syntax:** `pureds enable management`

Default Value:

By default, no directory service is configured. All authentication strictly uses locally defined accounts.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 <u>Centralize Account Management</u> Centralize account management through a directory or identity service.			
v8	6.7 <u>Centralize Access Control</u> Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.			

1.3 Ensure only authorized local administrative accounts exist and a local emergency-access account is retained (Manual)

Profile Applicability:

- Level 1

Description:

If your environment does not possess any mechanisms for delegated account management, or you have a need for additional local accounts for use as service accounts or for handling administration during network outages, FlashArray supports creating additional local administrative accounts.

If no management SAML configuration can be enabled, and no management LDAP directory service can be enabled, then Everpure recommends that you create one or more local administrators.

Rationale:

FlashArray can create local administrative accounts, and assign them a role to govern their permissions.

These accounts have a locally managed password and authorization policies. Local administrative users may also login via SSH using a public key or SSH certificates if configured, and may login via the REST API with an API Token or OAuth JWTs if configured.

Impact:

Deleting or disabling local accounts for users who still require access will lock them out of the array. If all local accounts are removed and the directory service becomes unavailable simultaneously, administrative access may be unrecoverable without Everpure Technical Services involvement. Always maintain at least one local emergency access account with array_admin privileges.

Audit:

To align with the security recommendations, verify that all local administrative accounts on the array correspond to authorized users or active service accounts, and that any stale or former employee accounts have been removed.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- Under the **Array** tab, review the **Users** panel to inspect the list of configured local accounts.
- Compare this list against your organization's authorized personnel and service accounts, verifying that accounts for former employees or decommissioned services no longer exist.

From the CLI:

- Run the command `pureadmin list` to enumerate all local administrator accounts.
- Review the output to confirm each account has a documented business justification and is actively required.

Remediation:

To align with the security recommendations, delete any local user accounts that are no longer authorized to access the FlashArray. Always ensure you maintain at least one local emergency access account with `array_admin` privileges in the event directory services or SAML become unavailable.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- In the **Users** panel, click the Edit (three vertical dots) icon for the user account you want to remove and select **Delete User...**
- In the Delete User pop-up window, click **Delete** to confirm.

From the CLI:

- Delete an unauthorized or stale account using the `pureadmin delete` command.
- *Command Syntax:* `pureadmin delete <USERNAME>`
- *Example:* `pureadmin delete obsolete_admin` (Note: Once deleted, the user can no longer access the array, and deleted users cannot be restored).

Default Value:

By default, the FlashArray is delivered with a single local administrative account named pureuser. The pureuser account is assigned the array_admin role and cannot be renamed or deleted. Additional service accounts may have been created during initial deployment depending on your environment.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.1 <u>Establish and Maintain an Inventory of Accounts</u> Establish and maintain an inventory of all accounts managed in the enterprise. The inventory must include both user and administrator accounts. The inventory, at a minimum, should contain the person's name, username, start/stop dates, and department. Validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.			
v8	5.3 <u>Disable Dormant Accounts</u> Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.			

1.4 Ensure administrators and directory groups are granted least-privilege roles via management access policies (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray provides utilities for role based access controls, with 4 built-in management access policies, which can be assigned to administrators, directory service groups, or as the maximum role that can be granted by OAuth API Clients.

Management access policies may be dynamically created, allowing you to grant users different roles in different scopes (e.g. different realms). Everpure recommends the following:

- Use more than one management access policy if you possess multiple users administering the system.
- Create at least 1 realm in order to create logical units of management for the purpose of delegating administration.
- Grant users and groups only the permissions needed to perform their responsibilities, utilizing custom management access policies to limit user access to the scopes containing objects for which they are responsible.

Rationale:

FlashArray provides 4 built-in management access policies:

- **array_admin**: This policy has the "admin" role over the full array scope. This role can perform all administrative capabilities on the system, including management of other administrators, authentication mechanisms, IDPs, storage, and networking.
- **storage_admin**: This policy has the "storage" role over the full array scope. This role can manage all storage objects, such as file systems and snapshots, and can read all other system configurations such as networking.
- **ops_admin**: This policy has the "support" role over the full array scope. This role can manage supportability configurations, such as enabling remote assist, and can read all other system configurations.
- **readonly**: This policy has the "viewer" role over the full array scope. This role can read all system configurations.

The noted roles can be assigned to other scopes within management access policies in order to grant users with those policies those same permissions but in a different scope. There are some limitations; physical networking and IDPs can only be managed by admins of the full array scope, though logical networking can still be managed by admins within a realm scope.

In order to reduce the risk of a compromised account, different administrators, or groups of administrators, should be assigned to the minimal role needed to accomplish their responsibilities. Granting every user full administrative privileges is a security risk.

This includes ensuring that realms are created as logical units to house configurations and data managed by a specific organization or team. Even if only one team within your organization currently utilizes FlashArray, creating a realm for that single team ensures that there will be no authorization risks or migrations if another team is granted use of the system with their own realm later.

Impact:

Reducing a user's role to the minimum necessary may prevent them from performing tasks they previously could, which may require workflow adjustments. All role changes should be communicated to affected users in advance.

Audit:

To align with the security recommendations, verify that administrators and directory service groups are granted the minimum necessary privileges (e.g., readonly, storage_admin, ops_admin, or array_admin) using Management Access Policies. Ensure that no user or group has an unnecessarily broad access policy assigned.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- In the **Users** panel, review the **Policies** (or Access Policy) column for each local account to verify the appropriate privilege levels are assigned.
- In the **Directory Service** panel, review the **Roles** section to confirm that directory service group-to-role mappings are securely defined and align with the principle of least privilege.

From the CLI:

- Run the command `pureadmin list` to display all local administrators.
- Review the Access Policy column in the output to confirm that each account has the appropriate minimum-privilege policy attached (and no account is unnecessarily set to array_admin).
- Run the command `pureds role list` to display the current LDAP/AD group to Purity//FA access policy mappings and verify their assignments.
- Run `purepolicy management-access list` to inspect the permissions, scopes, and aggregation strategies of all configured access policies.

Remediation:

To align with the security recommendations, assign users and groups the minimum role needed to accomplish their responsibilities by leveraging Purity//FA's built-in or custom Management Access Policies.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- **For Local Users:** In the **Users** panel, click the edit (three vertical dots) icon for the user account and select **Change Access Policy**. Remove any overly permissive policies and assign the appropriate minimum-privilege policy.
- **For Directory Service Groups:** In the **Directory Service** panel, click the edit icon in the **Roles** section. Change the Active Directory/LDAP group mapping so that the group is mapped to the appropriate minimum-privilege RBAC role, then click **Save**.

From the CLI:

- **Update a local user's access policy:** Attach the correct minimum-privilege management access policy using `pureadmin add`, and remove the non-compliant policy using `pureadmin remove`.
- *Command Syntax (Add):* `pureadmin add --access-policy <ACCESS_POLICY> <USERNAME>`
- *Command Syntax (Remove):* `pureadmin remove --access-policy <ACCESS_POLICY> <USERNAME>`
- *Example:* `pureadmin add --access-policy storage_admin admin1`
- **Update a directory service group mapping:** Create or update the named mapping to attach an LDAP group to the correct Purity//FA access policy.
- *Command Syntax:* `pureads role create <MAPPING_NAME> --access-policy <ACCESS_POLICY> --group <AD_GROUP> --group-base <OU>`
- *Example:* `pureads role create storagemap --access-policy storage_admin --group purestorageadmins --group-base OU=Storage,DC=company,DC=com`

Default Value:

By default, the FlashArray is delivered with a single local administrative account named `pureuser`. This account is permanently attached to the `array_admin` access policy, which grants full array-wide permissions, and it cannot be altered. Directory service group mappings and custom management access policies are not configured by default.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>6.8 Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			

1.5 Ensure SSH key-based authentication is configured for CLI access, preferably sourced from LDAP (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray allows for SSH public keys to be retrieved from a configurable attribute within a configured LDAP server if delegated account management with LDAP is in use.

If this is not viable in your environment, or local administrative accounts are in use, then SSH public key based authentication can be configured locally per-user.

Everpure recommends that SSH keys be retrieved from LDAP.

Rationale:

Retrieval of SSH keys from LDAP allows for authentication to be centrally managed, and ensures any compromised key can be removed from trust across your environment with a single change.

If this is not possible, individual administrators may configure SSH Public Keys for their accounts. This allows them to login with the corresponding private key instead of a password.

Impact:

SSH key-based authentication requires administrators to manage key pairs securely. Loss of a private key without a registered backup key would require an administrator with array_admin access to remove and re-register the key. If password authentication is subsequently disabled, a lost or revoked key could lock an administrator out of CLI access until the key is replaced.

Audit:

To align with the security recommendations, verify that SSH public keys are configured for users requiring CLI access (to prevent reliance on passwords) and test that the key-based authentication functions correctly.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- In the **Users** panel, verify that a masked key is present in the **Public Key** column for each user who accesses the array via the CLI.
- **Test the configuration:** Using an SSH client (such as PuTTY or the native UNIX `ssh` command), attempt to log in to the FlashArray as the target user with the corresponding private key to verify that authentication succeeds without prompting for a password.

From the CLI:

- Run the command `pureadmin list --publickey to display all users` and their public key status.
- Review the output to confirm that all authorized CLI users have a public key configured.
- **Test the configuration:** Initiate an SSH connection to the array from an administrative workstation using the user's private key to ensure successful authentication.

Remediation:

To align with the security recommendations, configure SSH public keys for your administrative accounts so they can authenticate securely using a private key rather than a password.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- In the **Users** panel, click the Edit (three vertical dots) icon for the user you want to modify and select **Edit User....**
- In the Edit User pop-up window, select **Overwrite** and paste the user's SSH public key into the **Public Key** field.
- Click **Save**.

From the CLI:

- **Add a public key:** Initiate the configuration for a specific user using the `pureadmin setattr` command.
- **Command Syntax:** `pureadmin setattr --publickey <USERNAME>`
- **Action:** Purity//FA will prompt you interactively to enter the public key. Paste the public key, press Enter to insert a new line, and then press CTRL-D to exit the prompt and save the key.
- **Verify the key:** Confirm the key was successfully registered.
- **Command Syntax:** `pureadmin list --publickey <USERNAME>`

Default Value:

By default, no SSH public keys are configured. All CLI access strictly uses password-based authentication out of the box.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.6 <u>Securely Manage Enterprise Assets and Software</u> Securely manage enterprise assets and software. Example implementations include managing configuration through version-controlled-infrastructure-as-code and accessing administrative interfaces over secure network protocols, such as Secure Shell (SSH) and Hypertext Transfer Protocol Secure (HTTPS). Do not use insecure management protocols, such as Telnet (Teletype Network) and HTTP, unless operationally essential.			

1.6 Ensure brute-force lockout is set to 3 attempts with a lockout duration of at least 1 hour (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray supports controls to prevent brute-force guessing of passwords. These controls cause a user to be locked out after a configurable number of consecutive failed password attempts. The lockout lasts for a configurable duration of time.

Everpure recommends the following:

- The number of consecutive password failures before lockout should be 3.
- The lockout duration should be no less than 1 hour.

Rationale:

Password login is necessary in many environments, but brute-force password guessing is always a risk that comes with it. Configuring brute-force protection can help mitigate that risk.

Impact:

Account lockout may inadvertently lock out legitimate administrators due to mistyped passwords or failed automation scripts. A lockout duration that is too long may delay access in time-sensitive situations. An administrator with array_admin privileges can manually unlock affected accounts via the CLI.

Audit:

To align with the security recommendations, verify that the array is configured to lock out users after a maximum of 3 failed login attempts, with a lockout duration of at least 60 minutes.

From the GUI:

- Navigate to **Settings > Access > Password Policy**.
- Review the global password policy and verify the **Maximum Login Attempts** is set to 3 (or fewer, but greater than zero).
- Verify that the **Lockout Duration** is configured to at least 60 minutes.

From the CLI:

- Run the command `purepolicy password list to display the configuration of the global password policy` (named management).
- Review the output to confirm that the Enabled status is True.
- Review the Attribute and Value columns to confirm that Maximum Login Attempts is 3 or lower, and Lockout Duration is 60m or longer.
- *(Optional)* Run the command `pureadmin list --lockout` to display any users that are currently locked out by the system.

Remediation:

To align with the security recommendations, configure the global password policy to enforce brute-force lockout protections and ensure the policy is actively enabled.

From the GUI:

- Navigate to **Settings > Access > Password Policy**.
- Modify the password policy settings: set the **Maximum Login Attempts** to 3 and the **Lockout Duration** to 60 (minutes).
- Ensure the policy is toggled to **Enabled** and click **Save**. *(Note: If a legitimate administrator is inadvertently locked out, you must unlock their account manually from the CLI, as there is no specific GUI toggle documented for unlocking accounts in 6.9.x).*

From the CLI:

- **Configure the lockout thresholds:** Set the lockout attributes on the global password policy (which applies to all local accounts) using the `purepolicy password setattr` command.
- *Command Syntax:* `purepolicy password setattr --max-login-attempts <ATTEMPTS> --lockout-duration <DURATION> management`
- *Example:* `purepolicy password setattr --max-login-attempts 3 --lockout-duration 60m management`
- **Enable the password policy:** Ensure the management password policy is active.
- *Command Syntax:* `purepolicy password enable management`
- **Unlock a locked account:** If an administrator account is locked out and needs to be restored before the duration naturally expires, an `array_admin` can immediately reset the lockout.
- *Command Syntax:* `pureadmin reset <USERNAME> --lockout`
- *Example:* `pureadmin reset admin1 --lockout`

Default Value:

By default, the FlashArray does not strictly enforce a lockout threshold. The global password policy features minimal requirements out of the box and lockout policies must be explicitly configured by the administrator.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			

1.7 Ensure the password policy enforces 8+ characters, 3+ character groups, and username and dictionary checks (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray supports a password policy for administrative user passwords. It allows rules to be configured governing complexity requirements, such as minimum length, number of required unique character groups (e.g. letters, numbers, symbols), and whether a user's username may appear in their password.

Everpure recommends the following:

- The minimum password length should be 8 characters.
- The minimum number of character groups should be 3.
- The username check should be enabled.
- The dictionary check should be enabled.

Rationale:

Password login is necessary in many environments, so enforcing password complexity can help mitigate that risk of passwords being guessed.

Longer passwords with more complex character sets are harder to brute-force. Avoiding passwords containing an admin's username or common words can also help reduce the ability to brute force guess passwords.

Impact:

Enforcing strong password complexity may cause friction for administrators accustomed to simpler passwords. Password rotation requirements introduce a maintenance burden and may result in temporary lockouts if rotation is not performed in time. Automated monitoring or reminders should be established for accounts approaching their password expiry.

Audit:

To align with the security recommendations, verify that the array enforces strong password complexity for local administrators, specifically requiring a minimum length of 8 characters, at least 3 character groups, and actively enforcing both dictionary and username checks.

From the GUI:

- Navigate to **Settings > Access > Password Policy**.
- Verify the **Minimum Password Length** is set to at least 8 characters.
- Verify the **Minimum Character Groups** requirement is set to at least 3.
- Verify that the **Enforce Username Check** and **Enforce Dictionary Check** toggles are enabled.

From the CLI:

- Run the command `purepolicy password list to display the current configuration of the global password policy` (named management).
- Review the output to confirm the following Attribute and Value pairs are compliant:
 - Minimum Password Length is 8 or greater.
 - Minimum Character Groups is 3 or greater.
 - Enforce Dictionary Check is True.
 - Enforce Username Check is True.

Remediation:

To align with the security recommendations, configure the global password policy to mandate longer passwords, require multiple character groups, and prevent the use of easily guessable dictionary words or usernames.

From the GUI:

- Navigate to **Settings > Access > Password Policy**.
- Set the **Minimum Password Length** to 8 (or more).
- Set the **Minimum Character Groups** to 3.
- Ensure the toggles for **Enforce Username Check** and **Enforce Dictionary Check** are enabled.
- Click **Save**.

From the CLI:

- **Configure Length and Complexity:** Set the minimum password length and character group requirements using the `purepolicy password setattr` command.
- **Command Syntax:** `purepolicy password setattr --min-password-length <LENGTH> --min-character-groups <COUNT> management`
- **Example:** `purepolicy password setattr --min-password-length 8 --min-character-groups 3 management`
- **Enable Dictionary and Username Checks:** Enable the specific security checks on the management password policy using the `purepolicy password enable` command.
- **Command Syntax:** `purepolicy password enable --username-check --dictionary-check management`

Default Value:

By default, the FlashArray password policy has minimal requirements. The Minimum Password Length defaults to 1 character, the Minimum Character Groups defaults to 1, and both Enforce Dictionary Check and Enforce Username Check are set to False. Complexity and rotation policies must be explicitly configured by the administrator.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 <u>Use Unique Passwords</u> Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			

1.8 Ensure OAuth API clients use least-privilege access policies and access-token TTLs of 60 minutes or less (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray supports configuring one or more identity providers for API Clients. These IDPs can then issue identity tokens to any user on the array that can be exchanged with the array for API access using the OAuth2 standard.

The configuration also allows you to specify maximum permissions that can be granted to users who receive id tokens from the IDP, as well as the TTL for access tokens issued to clients.

Everpure recommends the following:

- All API Clients should be configured with appropriately limited permissions based on the use case of the IDP.
- All API Clients should be configured with a TTL of 60 minutes or fewer.

Rationale:

The OAuth2 specification allows for short-lived access tokens to be issued and used for API access. Use of short-lived tokens can substantially reduce the impact of a compromise, as the tokens have a limited window of use.

Limiting the granted permissions for API Clients can also have value. If a user desires to run API automation, such as workload performance monitoring, or snapshot management, it is not necessary to authorize that automation with the full permissions of the user.

By utilizing an appropriately configured OAuth API Client, you can restrict applications to readonly or storage_admin permissions, even when they act on behalf of a user who may be an array_admin. This limits the impact of a compromised application on the system.

Impact:

Deleting or modifying active API clients will immediately invalidate all tokens issued to those clients, breaking any integrations or automation workflows that use them. Changes to API client configuration should be planned and communicated to affected teams before implementation.

Audit:

To align with the security recommendations, verify that all configured API clients have a documented business purpose, are assigned the minimum necessary permissions (e.g., readonly instead of array_admin), and utilize short-lived access tokens (TTL of 60 minutes or less) to reduce the impact of a compromised token.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- Scroll to the **API Clients** panel and review the list of configured API clients.
- Verify each active API client has a documented business purpose.
- Review the access policy and TTL assigned to each client to ensure they enforce the principle of least privilege.

From the CLI:

- Run the command `pureapiclient list` to display all configured API clients.
- Review the output to verify the Access Policy, Enabled status, and token TTL for each client.
- Verify no API clients are enabled that are no longer actively in use.

Remediation:

To align with the security recommendations, delete or disable inactive API clients, and ensure all active clients are bound to restrictive access policies with short-lived tokens. *(Note: Modifying or deleting an active API client will immediately invalidate its issued tokens, so changes should be coordinated with the teams responsible for those integrations).*

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- In the **API Clients** panel, select any unused clients and click the trash icon to delete them.
- For active clients, click the edit icon to reduce the assigned access policy or shorten the token TTL as appropriate.
- To create a new compliant client, click the **+** (Create API Client) icon. In the pop-up window, enter the client name, select a minimum access policy (e.g., readonly), set the time to live (e.g., 1h), and paste the RSA public key in PEM format, then click **Create**.

From the CLI:

- **Disable an unused API client:** Use the `pureapiclient disable` command to temporarily revoke a client's access.
- *Command Syntax:* `pureapiclient disable <CLIENT_NAME>`
- **Delete an unused API client:** Use the `pureapiclient delete` command to permanently remove an obsolete client.
- *Command Syntax:* `pureapiclient delete <CLIENT_NAME>`
- **Create a new, least-privilege API client:** Use the `pureapiclient create` command, specifying a restrictive access policy and a short token TTL.
- *Command Syntax:* `pureapiclient create --access-policy readonly --access-token-ttl 1h --public-key <CLIENT_NAME>`
- *Action:* Purity//FA will prompt you interactively to enter the public key. Paste the public key, press Enter to insert a new line, and then press CTRL-D to exit the prompt and create the client.

Default Value:

By default, no OAuth API clients are configured on the FlashArray.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts</u> Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			
v8	<u>6.8 Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			

1.9 Ensure static REST API tokens are used only when necessary and configured to expire periodically (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray supports administrators creating static API for REST API access. This should only be utilized in cases where OAuth usage is not feasible.

Everpure recommends the following:

- REST API tokens can be configured to expire. If REST API tokens are configured, configure them to expire periodically.
- Only create REST API tokens if no API Clients for OAuth can be created and enabled for REST access.
- If REST API tokens are configured, it is highly recommended that you monitor which IP addresses access the REST API.

Rationale:

API Tokens are a custom mechanism for REST API access, with no standardized mechanism for rotation. As such, changing them is more difficult. But making them non-expiring increases the risk of compromise, because a one-time exposure of the token can lead to compromise for an indefinite window of time.

API Tokens also act exactly as the user who creates them, with full permissions. So an API token created by an array_admin for something like performance monitoring can still act with full array_admin rights. As such, a compromised application using API Tokens cannot have the impact limited by compensating controls around the role assigned to the token.

As such, the only compensating control to reduce the impact of a compromised API Token are network access controls to the REST API.

Impact:

Deleting an API token that is actively used by an automation tool or integration will immediately break that integration. All token changes should be made in coordination with the teams responsible for API consumers.

Audit:

To align with the security recommendations, verify that static API tokens are only issued when OAuth usage is not feasible, that tokens are assigned only to accounts with the minimum necessary privileges, and that tokens are configured to expire periodically to reduce the risk of long-term compromise.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- In the **Users** panel under the **Array** tab, check the **API Token** column to see which users have a masked token present.
- For users with a token, click the Edit (three vertical dots) icon and select **Show API Token...** to view the token details.
- Review the token creation and expiry dates. Verify that only accounts actively requiring API access have tokens, and that they enforce an appropriate expiration timeframe.

From the CLI:

- Run the command `pureadmin list --api-token` to list all accounts and their API token status.
- Review the Created and Expires columns to identify tokens that lack an expiration date (indicated by a -) or have existed longer than the organization's rotation policy allows.
- Verify that each token-holding account is assigned the minimum required management access policy.

Remediation:

To align with the security recommendations, delete unauthorized or stale API tokens, and ensure that any newly issued tokens are configured with a strict validity period (timeout) so they expire automatically.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- In the **Users** panel, click the Edit icon for the user you want to modify.
- **To delete a token:** Select **Remove API Token...** and click **Remove** to confirm.
- **To rotate or create an expiring token:** Select **Create API Token...** (or **Recreate API Token...** to overwrite an existing one). In the prompt, enter a validity period in the **Expires In** field so the token does not live indefinitely, then click **Create**.

From the CLI:

- **Delete an existing API token:**
- *Command Syntax:* `pureadmin delete --api-token <USERNAME>`
- **Create a new API token with an expiration:** Ensure you use the `--timeout` flag to enforce an expiry period (e.g., s, m, h, d, or w).
- *Command Syntax:* `pureadmin create --api-token --timeout <PERIOD> <USERNAME>`
- *Example:* `pureadmin create --api-token --timeout 30d pureuser`
- **Retrieve the new token for the consumer:**
- *Command Syntax:* `pureadmin list --api-token --expose <USERNAME>`
(Note: Store the token securely in a secrets manager. Never embed tokens in plaintext configuration files).

Default Value:

By default, API tokens are not created for new accounts. The pureuser account may have an API token generated during initial setup. When an API token is created without specifying a timeout, it is created without an expiry date and is valid until manually deleted or recreated.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.3 <u>Disable Dormant Accounts</u> Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.			
v8	5.4 <u>Restrict Administrator Privileges to Dedicated Administrator Accounts</u> Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			

1.10 Ensure administrative audit logs are forwarded to remote syslog or monitored via the REST API (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray creates administrative audit records for all administrative operations that cause a change to the system configuration or state.

Everpure recommends that these logs be monitored via REST API, or sent to configured remote syslog servers in order to detect suspicious or unexpected activity and respond accordingly.

Rationale:

The FlashArray administrative audit records track the following information for every operation that changes configuration or state:

- The time when it was performed
- The user who performed the action
- The origin array they performed the action from (in case it was performed from another array in the fleet)
- The equivalent CLI command, sub-command, and arguments representing the change that was performed

These pieces of information are valuable for detecting changes to the system state in unexpected configuration areas, by unexpected users, or originating from unexpected locations.

Impact:

Continuous audit log monitoring requires storage capacity and processing power on the receiving SIEM. The volume of audit events scales with administrative activity. SIEM integration must be configured and maintained to avoid log loss.

Audit:

To align with the security recommendations, verify that audit logs are continuously monitored—either by forwarding them to a remote syslog server or by polling them via the REST API—and that reviewers are checking the time, user, origin array, and executed commands.

From the GUI:

- **Verify Syslog Forwarding:** Navigate to **Settings > System**. In the **Syslog Servers** panel, verify that at least one remote syslog server is actively configured to receive audit events.
- **Verify Manual/API Log Access:** Navigate to **Settings > Access** and scroll to the **Audit Trail** pane. Confirm logs are accessible and capture the Time, User, Origin, and Command fields.
- **Verify REST API (If Syslog is not used):** Navigate to **Settings > Access > Users and Policies** (API Clients pane) and verify that an active API Client or service account exists for your SIEM/monitoring platform to poll the REST API.

From the CLI:

- **Verify Syslog Forwarding:** Run the command `purelog syslog list`. Review the output to confirm a remote syslog server URI is configured.
- **Verify Audit Records:** Run the command `pureaudit list` (or `pureaudit list --filter "time >= '<YYYY-MM-DD>'"` for recent events). Review the output to ensure the Time, User, Command, and Arguments are being accurately recorded.
- **Verify REST API (If Syslog is not used):** Verify with your monitoring teams that an active external script or tool is successfully authenticating and pulling the audit logs via the FlashArray REST API.

Remediation:

To align with the security recommendations, implement continuous monitoring by configuring external syslog forwarding or REST API integration, and establish a process to review unexpected configurations.

From the GUI:

- **To Configure Syslog Forwarding:**
- Navigate to **Settings > System**.
- In the **Syslog Servers** panel, click the **+** (Create) icon.
- Enter the URI of your remote syslog server (e.g., tcp://10.10.10.10:514) and click **Create**.
- **To Configure REST API Monitoring:**
- Integrate your SIEM or monitoring tool using the Pure Storage REST API endpoints to continuously poll for audit trail events.
- **Establish a Review Process:** Ensure your monitoring team or SIEM alerts analyze the logs specifically for unexpected Users, Origin arrays, or Commands that change system state.

From the CLI:

- **To Configure Syslog Forwarding:** Create a remote syslog server destination using the `purelog syslog create` command.
- *Command Syntax:* `purelog syslog create --uri <URI> <SERVER_NAME>`
- **Establish a Review Process:** If manually reviewing, use the `pureaudit list` command periodically. You can isolate specific users or times using the `--filter` flag (e.g., `pureaudit list --filter "user='pureuser'"`).

Default Value:

By default, FlashArray continuously records audit events locally and retains them for up to 90 days (or 10GB). External forwarding to remote syslog servers or REST API polling is not configured out of the box.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 <u>Collect Audit Logs</u> Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.			
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			

1.11 Ensure administrative session logs are forwarded to remote syslog or monitored via the REST API (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray creates administrative session records for all administrative logins and logouts, whether successful or unsuccessful.

Everpure recommends that these logs be monitored via REST API, or sent to configured remote syslog servers in order to detect suspicious or unexpected activity and respond accordingly.

Everpure recommends that you monitor these logs in order to detect use of weak authentication mechanisms.

Rationale:

The FlashArray administrative session logs track the following information for every attempted or successful login, and logout:

- The time when it occurred or began
- The time when the session ended, if login had been successful
- The user associated with the login
- The product interface where the login was attempted (e.g. CLI)
- The IP address they performed the login from
- The event itself (e.g. failed authentication, "login" if the user has not yet logged out, or "user session" for a completed session)
- The method used to attempt authentication (e.g. certificate, saml2_sso, password, public key)
- The event count, which is greater than 1 if multiple failed login attempts occurred in a short period of time

These pieces of information are valuable for detecting attempted or successful intrusion into the system, use of compromised keys for login, or logins originating from unexpected locations.

These pieces of information can also be used to detect logins made using unexpected credentials (e.g. a user logging in with an API Token when OAuth is available; a user logging in with a password when SSH public keys are configured).

Impact:

Continuous session monitoring requires ongoing operational processes.

Audit:

To align with the security recommendations, verify that administrative session logs are continuously monitored—either by forwarding them to a remote syslog server or by polling them via the REST API—and that reviewers are checking the start/end times, users, access interfaces, IP locations, and event types.

From the GUI:

- **Verify Manual/API Log Access:** Navigate to **Settings > Access** and locate the **Session Log** pane. Confirm logs are accessible and capture the Start Time, End Time, Interface, User, Location, and Event fields.
- **Verify Syslog Forwarding:** Navigate to **Settings > System**. In the **Syslog Servers** panel, verify that a remote syslog server is actively configured to receive events.
- **Verify REST API (If Syslog is not used):** Navigate to **Settings > Access > Users and Policies** (API Clients pane) to verify an active API Client exists for your SIEM/monitoring platform to poll session logs via the REST API.

From the CLI:

- **Verify Session Records:** Run the command `pure-session list` to display user session logs. Review the output to ensure Start Time, End Time, Interface, User, Location, and Event fields are being actively recorded.
- **Verify Syslog Forwarding:** Run the command `pure-log syslog list` to confirm a remote syslog server URI is configured.
- **Verify REST API (If Syslog is not used):** Verify with your monitoring teams that an external script is successfully polling the FlashArray REST API for session records.

Remediation:

To align with the security recommendations, implement continuous monitoring by configuring external syslog forwarding or REST API integration for session logs, and establish a process to review logs for weak authentication methods or unexpected access.

From the GUI:

- **Establish a Review Process:** Create a standard operating procedure to regularly review the **Session Log** pane under **Settings > Access** specifically looking for unexpected IP locations or failed authentication events.
- **To Configure Syslog Forwarding:** Navigate to **Settings > System**. In the **Syslog Servers** panel, click the + (Create) icon, enter your remote syslog server URI, and click **Create**.
- **To Configure REST API Monitoring:** Integrate your SIEM or monitoring tool using the Pure Storage REST API endpoints to continuously poll for session events.

Note: If credentials are believed to be compromised, immediately rotate the affected account's password using the **Users** pane and rotate API tokens.

From the CLI:

- **Establish a Review Process:** Implement an operational procedure to periodically run `pure session list` and review the output for unexpected session activity.
- **To Configure Syslog Forwarding:** Create a remote syslog server destination using the `purelog syslog create` command.
- *Command Syntax:* `purelog syslog create --uri <URI> <SERVER_NAME>`
- *Example:* `purelog syslog create --uri tcp://10.10.10.10:514 syslog-server01`

Default Value:

By default, user session tracking is always active on the FlashArray. External forwarding of session events to remote syslog servers or REST API polling is not configured out of the box.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 <u>Collect Audit Logs</u> Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.			
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			

1.12 Ensure system alerts are actively monitored via remote syslog or email alert watchers (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray creates alerts for a variety of system conditions that may be cause for concern. Not all of these are security related, but a number of them are either directly security related or can have an impact on security.

Everpure recommends that these alerts be monitored via REST API, or sent via syslog to configured remote syslog servers, via email using the configured SMTP relay, or via remote SNMP managers, in order to detect alerts of concern and respond accordingly.

Rationale:

The FlashArray alerts cover a variety of cases, including but not limited to:

- Expiring certificates
- Insecure default credentials in use
- Drive removal
- Hardware cable removal
- Snapshot limits being approached

Some alerts, such as default credentials, directly impact security. However, even for alerts that do not always directly pertain to security, they can potentially indicate attempts at physical tampering with the system, such as blade removal, or indicate system states that impact other security controls, such as approaching snapshot limits that impact data protection.

As such, alerts should be appropriately monitored and acted upon.

Impact:

Excessive alert configuration can lead to alert fatigue if low-severity events are forwarded to on-call teams. Alert routing should be tuned to ensure high-severity events receive immediate attention while informational events are logged to monitoring dashboards.

Audit:

To align with the security recommendations, verify that array alerts are actively monitored—either by forwarding them to a remote syslog server or by configuring an internal email address (alert watcher)—to ensure timely notification of security and system events.

From the GUI:

- **Verify Alert Watchers (Email):** Navigate to **Settings > System** and select **Alerts and Notifications** from the left navigation pane. Verify that at least one valid internal email address is listed to receive alerts.
- **Verify Syslog Forwarding:** Navigate to **Settings > System**. Locate the Syslog Servers panel and verify that a remote syslog server is actively configured to receive alert messages.

From the CLI:

- **Verify Alert Watchers (Email):** Run the command `purealert watcher list`. Review the output to ensure that an internal organization email address is configured and enabled to receive notifications.
- **Verify Syslog Forwarding:** Run the command `purelog syslog list`. Review the output to confirm that a remote syslog server URI is actively configured to receive events (which includes purity.alert records).

Remediation:

To align with the security recommendations, implement a continuous alerting process by configuring an email alert watcher or remote syslog forwarding (or both).

From the GUI:

- **To Configure Alert Watchers (Email):**
- Navigate to **Settings > System** and select **Alerts and Notifications** in the navigation pane.
- Add the appropriate internal email address for your organization's monitoring or administrative team to receive alert notifications.
- **To Configure Syslog Forwarding:**
- Navigate to **Settings > System**.
- In the Syslog Servers panel, create a syslog server by entering the URI of your remote syslog server (e.g., tcp://10.10.10.10:514) and saving the configuration.

From the CLI:

- **To Configure Alert Watchers (Email):** Add a designated email address using the `purealert watcher create` command.
- *Command Syntax:* `purealert watcher create <EMAIL_ADDRESS>`
- *Example:* `purealert watcher create soc-alerts@mycompany.com`
- **To Configure Syslog Forwarding:** Create a remote syslog server destination using the `purelog syslog create` command.
- *Command Syntax:* `purelog syslog create --uri <URI> <SERVER_NAME>`
- *Example:* `purelog syslog create --uri tcp://10.10.10.10:514 syslog-server01`

Default Value:

By default, the address flasharray-alerts@purestorage.com is designated as an alert watcher to transmit alerts to Pure Storage Technical Services. No internal organizational email watchers or remote syslog servers are configured out of the box.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 <u>Collect Audit Logs</u> Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.			
v8	8.11 <u>Conduct Audit Log Reviews</u> Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.			

1.13 Ensure at least one alert watcher is configured to receive alerts of all severities (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray allows configuration of one or more alert watchers, which are email addresses that will receive emails for new system alerts. The minimum severity of alerts that will be sent to each watcher is also configurable.

Everpure recommends that you configure at least 1 alert watcher that receives alerts of all severities.

Rationale:

While it may be helpful to have some administrators or monitors only receive emails about critical system alerts, responding to or monitoring alerts of lower severity can help ensure that they do not become critical.

As such Everpure recommends that you have at least 1 alert watcher that receives all alerts.

Impact:

Configuring alert watchers may result in notification emails to team members at any hour. Confirm that distribution lists are monitored around the clock for critical production arrays.

Audit:

To align with the security recommendations, verify that at least one organizational email address is configured as an alert watcher to receive all system alerts.

From the GUI:

- Navigate to **Settings > System** and select **Alerts and Notifications** in the left navigation pane.
- Locate the **Alert Watchers** panel.
- Verify that at least one active, organizational email address is configured (in addition to the built-in purestorage.com address).
- Verify that the **Enabled** toggle is active (blue).

From the CLI:

- Run the command `purealert watcher list` to display configured alert recipients.
- Review the output to confirm an organizational email address is present and its status is enabled.
- Verify that the Minimum Notification Severity is set to info so that the watcher receives alerts of all severities. *(Note: The CLI command output will show the active severity levels)*

Remediation:

To align with the security recommendations, configure an organizational email address to monitor array alerts.

From the GUI:

- Navigate to **Settings > System** and select **Alerts and Notifications**.
- In the **Alert Watchers** panel, click the **+** (Create) icon, enter the desired email address, and click **Create**.
- To adjust the notification level, click the **More Options** menu next to the newly created watcher, select **Edit**, choose the minimum severity, and click **Save**.
- Ensure the **Enabled** switch is toggled on.

From the CLI:

- **Create the watcher:** Run the `purealert watcher create` command.
- *Command Syntax:* `purealert watcher create <EMAIL_ADDRESS>`
- **Set the severity level:** Configure the minimum notification severity through an alert-watcher policy rule.
 - *Command Syntax:* `purepolicy alert-watcher rule add --email <EMAIL_ADDRESS> --minimum-notification-severity {critical|info|warning} <ALERT_POLICY>`
 - *Alternatively, update an existing rule:* `purepolicy alert-watcher rule setattr --rule-name <RULE> --minimum-notification-severity {critical|info|warning} <ALERT_POLICY>`
 - *Example:* `purepolicy alert-watcher rule add --email soc-alerts@mycompany.com --minimum-notification-severity info alert_policy_main`
- **Enable the watcher:** Ensure the watcher is actively receiving alerts using the `purealert watcher enable` command.
- *Command Syntax:* `purealert watcher enable <EMAIL_ADDRESS>`

Default Value:

By default, the address flasharray-alerts@purestorage.com is designated as a built-in alert watcher to transmit alerts to Pure Storage Technical Services, and it cannot be deleted. No internal organizational email watchers are configured out of the box.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.11 <u>Conduct Audit Log Reviews</u> Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.			

1.14 Ensure at least one remote management syslog server is configured (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray allows the creation of management syslog servers. These servers receive messages for administrative audit logs, administrative session logs, and alerts.

Everpure recommends that you configure at least 1 management syslog server.

Rationale:

Syslog servers allow proactive push notifications of changes and events on the system, which can allow for real-time detection and response to unexpected events.

Impact:

Syslog forwarding consumes network bandwidth and requires available capacity on the receiving syslog server. If the syslog server becomes unreachable, the FlashArray will continue to operate normally but may buffer or lose unsent log entries, depending on configuration.

Audit:

To align with the security recommendations, verify that at least one remote management syslog server is configured to receive proactive push notifications for administrative audit logs, session logs, and alerts.

From the GUI:

- Navigate to **Settings > System**.
- Locate the **Syslog Servers** panel.
- Verify that at least one remote syslog server is actively configured to receive events.

From the CLI:

- Run the command `purelog syslog list`.
- Review the output to confirm that at least one remote syslog server URI is actively configured.

Remediation:

To align with the security recommendations, configure at least one management syslog server to allow for real-time detection and response to unexpected events.

From the GUI:

- Navigate to **Settings > System**.
- In the **Syslog Servers** panel, click the **+** (Create) icon.
- Enter the URI of your remote syslog server (e.g., `tls://10.10.10.10:6514`) and provide a name.
- Click **Create** to apply the configuration.

From the CLI:

- Configure a remote syslog server destination using the `purelog syslog create` command.
- *Command Syntax:* `purelog syslog create --uri <URI> <NAME>`
- *Example:* `purelog syslog create --uri tls://10.10.10.10:6514 syslog-server01`

Default Value:

By default, no management syslog servers are configured.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 <u>Collect Audit Logs</u> Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.			
v8	8.9 <u>Centralize Audit Logs</u> Centralize, to the extent possible, audit log collection and retention across enterprise assets.			

2 Environmental

This section describes the best practices pertaining to environmental security topics for Purity//FA 6.9, such as certificates, SAML channel security, Active Directory channel security, LDAP, Syslog and SMTP with TLS, SNMP, NTP and automated configuration testing.

2.1 Ensure array TLS certificates are CA-signed, adequately sized, and rotated at least every 90 days (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray allows certificates on the system to be centrally managed. This includes both "array-type" certificates, which the FlashArray storage array can use to represent itself to clients, and "external-type" certificates which can be the public certificates of certificate authorities that sign the certificates of other environmental resources or the public certificates of self-signed environmental resources.

Everpure recommends the following:

- All RSA certificates in use should have at least 2048-bit keys.
- All ECDSA certificates in use should have at least 256-bit keys.
- Only "external-type" certificates should be used as roots of trust for other environmental resources.
- All "array-type" certificates should be signed by a certificate authority.
- All "array-type" certificates should have a lifetime of at most 90 days.

Rationale:

RSA and ECDSA Key size recommendations are in-line with NIST standards to ensure cryptographic strength.

Using "external-type" certificates as roots of trust ensures that it is not possible to mistakenly upload a private key to the system for a configuration that does not require it.

Ensuring all "array-type" certificates are signed by a trusted certificate authority ensures that clients, whether for administrative TLS, S3, or another protocol can use a strong root of trust for communication with FlashArray. It also allows rotation of certificates to be done with no client disruption.

Rotating certificates periodically reduces the impact of a compromised private key.

Impact:

Certificate rotation requires a brief period during which the management interface may be inaccessible. Certificates have finite validity periods and must be renewed before expiry. Expired certificates will prevent proper TLS validation and generate security warnings. Automated certificate management (e.g., via ACME/Let's Encrypt or an enterprise CA) is strongly recommended to prevent unplanned certificate expiry.

Audit:

To align with the security recommendations, verify that the array uses an appropriately sized, CA-signed certificate with a maximum lifetime of 90 days, and that external certificates are properly utilized for roots of trust.

From the GUI:

- Navigate to **Settings > System** and locate the **SSL Certificate** panel.
- In the **Array Certificates** panel, click the active management certificate to view its details.
- Verify the following attributes for the array certificate:
- **Key Size** is at least 2048 (for RSA) or 256 (for ECDSA).
- **Issuer** is a trusted internal or public Certificate Authority (not "Everpure" or "Self-Signed").
- The duration between the **Valid From** and **Valid To** dates is 90 days or less.
- Scroll to the **External Certificates** panel and verify that any certificates used as roots of trust are configured here (ensuring they are external-type).

From the CLI:

- Run the command `purecert list` to display the active certificates on the array.
- Review the output to ensure the following for your array type certificates:
- The Issuer is a trusted Certificate Authority.
- The Key Size is at least 2048 (for RSA) or 256 (for ECDSA).
- The difference between the Valid From and Valid To dates does not exceed 90 days.
- Verify that roots of trust are explicitly stored and listed under the external Type.

Remediation:

To align with the security recommendations, generate a properly sized Certificate Signing Request (CSR), have it signed by your CA for a maximum of 90 days, import it, and manage your roots of trust using external certificates.

From the GUI:

- Navigate to **Settings > System** and locate the SSL Certificate / Array Certificates panel.
- Click the menu icon and select **Construct Certificate Signing Request**. Fill in the required attributes and ensure the key size meets the 2048-bit RSA or 256-bit ECDSA minimums. Click **Create** and download the CSR.
- Submit the CSR to your organization's trusted Certificate Authority and request that the signed certificate has a lifetime of 90 days or less.
- Once the CA returns the signed certificate, return to the GUI, click the menu icon, and select **Import Certificate** to replace the existing certificate.
- To configure roots of trust, navigate to the **External Certificates** panel and import the trusted CA's public certificates.
- Establish an operational process to rotate the array-type certificates every 90 days.

From the CLI:

- Prepare the Key & CSR: Construct a Certificate Signing Request using the `purecert csr create` command. (Note: Purity uses RSA 2048 by default. If you need to change the key algorithm to ECDSA or increase the key size, first run `purecert self-signed setattr --new-key --key-algorithm <ALGORITHM> --key-size <SIZE>` before generating the CSR.)
- *Command Syntax:* `purecert csr create <NAME> --common-name <FQDN>`
- Submit the generated CSR block to your Certificate Authority and request a signed certificate with a validity period of 90 days or less.
- **Import the Signed Certificate:** Once the CA returns the signed certificate, import it using the `purecert imported setattr` command. (*Append the `--intermediate-certificate` flag if required*).
- *Command Syntax:* `purecert imported setattr <NAME>`
- **Import Roots of Trust:** Ensure any CA root certificates are imported as external certificates rather than array certificates.
- Establish a continuous operational process (such as a scheduled automation script) to rotate these certificates every 90 days.

Default Value:

By default, the FlashArray creates and uses a Everpure self-signed RSA 2048-bit certificate valid for 3650 days (10 years) for management TLS communications. External roots of trust are not configured out of the box.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v8	4.6 <u>Securely Manage Enterprise Assets and Software</u> Securely manage enterprise assets and software. Example implementations include managing configuration through version-controlled-infrastructure-as-code and accessing administrative interfaces over secure network protocols, such as Secure Shell (SSH) and Hypertext Transfer Protocol Secure (HTTPS). Do not use insecure management protocols, such as Telnet (Teletype Network) and HTTP, unless operationally essential.			

2.2 Ensure SAML SSO uses HTTPS with encrypted assertions and signed requests (Manual)

Profile Applicability:

- Level 2

Description:

SAML may be used for delegated authentication across various protocols on FlashArray. The array URL, IDP metadata URL, and IDP URL are all required to use https if specified.

IDP Metadata URL usage is optional; if one is not used, then you may instead manually configure the IDP URL, verification certificate, and IDP entity ID.

It is recommended that encrypted assertions from the IDP be enabled if your IDP supports them, and a decryption certificate be configured.

It is recommended that signed requests from the array be enabled if your IDP supports them, and a signing credential be configured.

Rationale:

Encrypted assertions prevent the SAML assertions from your IDP from being read by entities other than the FlashArray array. This ensures that any sensitive information that may be in such assertions, such as PII, roles, or group memberships cannot be read by unintended actors.

Signed requests from the array ensure that the array cannot be impersonated in requests to the IDP. This prevents malicious actors from forging requests to your IDP in order to attempt to obtain information about arbitrary users or services.

Impact:

SAML certificate rotation requires coordination between the FlashArray administrator and the IdP administrator to ensure that the new SP certificate is updated in the IdP configuration before the old certificate expires, to avoid authentication outages.

Audit:

To align with the security recommendations, verify that the SAML SSO integration strictly utilizes HTTPS for all communication URLs, enforces encrypted assertions from the Identity Provider (IdP) to prevent interception, and enforces signed requests from the FlashArray to prevent impersonation.

From the GUI:

- Navigate to **Settings > Access > Users and Policies** and scroll to the **SAML2 SSO** pane.
- Review the configured URLs (**Array URL**, **IdP URL**, or **Metadata URL**) to verify they all utilize the https:// scheme.
- Click the edit icon for the Configuration.
- Verify that the **Sign Request** toggle is enabled (blue) and that a valid **Signing Credential** is configured.
- Verify that the **Encrypt Assertion** toggle is enabled (blue) and that a valid **Decryption Credential** is configured.
- Verify that the **Verification Certificate** is present, issued by a trusted Certificate Authority, and has not expired.

From the CLI:

- Display the full SAML2 SSO configuration and certificate details by running the command `puresso saml2 list --verification-certificate`.
- Review the output to confirm that the Array URL and IdP URL fields begin with https://.
- Verify that the Sign Request and Encrypt Assertion attributes are set to True.
- Review the Verification Certificate details to ensure it was issued by a trusted CA and the Valid To date is not expired.

Remediation:

To align with the security recommendations, update your SAML2 SSO configuration to require HTTPS, signed requests, and encrypted assertions using dedicated credentials.

From the GUI:

- Navigate to **Settings > Access > Users and Policies** and scroll to the **SAML2 SSO** pane.
- Click the edit icon for the Configuration.
- Update the **Array URL** and **IdP URL** fields to ensure they begin with https://.
- **Enable Signed Requests:** Slide the **Sign Request** toggle to the right (blue) and enter your array's signing certificate name in the **Signing Credential** field.
- **Enable Encrypted Assertions:** Slide the **Encrypt Assertion** toggle to the right (blue) and enter your array's decryption certificate name in the **Decryption Credential** field.
- If the **Verification Certificate** is expired or self-signed, click Edit to paste the new PEM-formatted certificate from your IdP.
- Click **Save**. *(Note: Always perform an E2E Test from the GUI after making SAML changes to ensure administrative access is not interrupted).*

From the CLI:

- **Secure the SAML configuration:** Update the URLs to HTTPS and set the signing/decryption credentials with `puresso saml2 setattr`, then turn on request signing and assertion encryption with `puresso saml2 enable`.
- **Command Syntax (set URLs and credentials):** `puresso saml2 setattr --array-url https://<ARRAY_FQDN> --idp-url https://<IDP_URL> --signing-credential <CRED_NAME> --decryption-credential <CRED_NAME> <IDP_NAME>`
- **Command Syntax (enable signing and encryption):** `puresso saml2 enable --sign-request --encrypt-assertion <IDP_NAME>`
- **Update the Verification Certificate:** If the IdP certificate is expired or self-signed, replace it using the `--verification-certificate` flag.
- **Command Syntax:** `puresso saml2 setattr --verification-certificate <IDP_NAME>`
- **Action:** Paste the new PEM-formatted certificate at the interactive prompt, press **Enter**, and then press **Ctrl-D**.

Default Value:

By default, SAML2 SSO is not configured on the FlashArray. When initially creating a SAML2 SSO configuration, the Sign Request and Encrypt Assertion security features are disabled by default.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

2.3 Ensure Active Directory accounts are configured to require TLS (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray supports native integration with Active Directory domains in order to enable LDAP lookups for authorization, and Kerberos authentication.

FlashArray does this by creating a computer account in the domain to represent itself and generate kerberos keys. A unique AD account may be created for each server on the array that needs one.

Everpure recommends that you configure TLS as required for all AD accounts. This is the default.

Rationale:

While Active Directory supports non-TLS LDAP communication, it is less secure than TLS and allows for traffic to potentially be tampered with or exposed.

Impact:

Requiring TLS for Active Directory communication depends on the domain controllers presenting valid certificates the array can validate. If a domain controller's certificate is untrusted or expired, AD authentication and LDAP lookups may fail until trust is re-established. DNS must be correctly configured for the array to locate the domain controllers and validate their certificates.

Audit:

To align with the security recommendations, verify that the array's Active Directory (AD) integration accounts are configured to require TLS, ensuring secure communication and preventing potential traffic tampering or exposure.

From the GUI:

- Navigate to **Settings > Access > Users and Policies** (for array management AD accounts) or navigate to **Storage > Servers** and select your file server (for file service AD accounts).
- Locate the **Active Directory Accounts** or **Remote Directory Service** panel.
- Open the configuration details for the connected AD account.
- Verify that the **TLS Mode** is set to required.

From the CLI:

- Run the command `puread account list` to display information about Active Directory account attributes.
- Review the output and verify that the TLS column for the configured AD account is set to required (rather than optional).

Remediation:

To align with the security recommendations, update your Active Directory account configuration to explicitly require TLS for all domain controller communications.

From the GUI:

- Navigate to **Settings > Access > Users and Policies** or **Storage > Servers** depending on where the AD account is applied.
- Edit the Active Directory configuration (e.g., in the Configure Remote Directory Service window).
- Under the **TLS Mode** setting, select the **required** radio button to force TLS communication with the domain controller.
- Click **Create** (or **Save**) to apply the configuration.

From the CLI:

- Update the Active Directory account to require TLS using the `puread account setattr` command.
- *Command Syntax:* `puread account setattr --tls required <NAME>`
- *Example:* `puread account setattr --tls required server1::ad-ad`

Default Value:

By default, Active Directory integration is not configured. When configuring a new Active Directory account, if the TLS mode is not explicitly specified, the option automatically defaults to required.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

2.4 Ensure LDAP directory services use LDAPS with a configured CA root of trust (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray supports LDAP directory services for administrative login and authorization, as well as for NFS authorization.

Everpure recommends the following:

- Utilize LDAPS in order to establish secure LDAP connections.
- Specify one or more certificate authorities as roots of trust for each LDAP directory service.

Rationale:

Encrypting LDAP communication with TLS is crucial to prevent malicious actors from inspecting or tampering with LDAP traffic pertaining to authorization.

Proper roots of trust are important for ensuring the TLS authenticity cannot be compromised, and such TLS traffic cannot be intercepted.

Impact:

LDAPS requires that the LDAP/AD server presents a valid TLS certificate. If the server's certificate is self-signed, you must import the CA certificate to the FlashArray for validation. Switching from LDAP to LDAPS may cause temporary authentication disruption during the transition.

Audit:

To align with the security recommendations, verify that the LDAP directory services utilize LDAPS to establish secure connections and that a Certificate Authority (CA) is configured as a root of trust.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- Locate the **Directory Service** panel.
- Select either the **Array Management** or **Data** view.
- Verify that the **URIs** field begins with ldaps:// rather than ldap://.
- Verify that a CA Certificate is configured by checking the **CA Certificate** field in the panel.

From the CLI:

- Inspect the directory service configuration by running the command `purefs list`.
- Review the output and confirm the URI field uses the ldaps:// scheme.
- Verify that a CA certificate is configured by running the command `purefs list --ca-certificate`.

Remediation:

To align with the security recommendations, update your directory service configuration to enforce LDAPS and configure the appropriate CA certificate for trust.

From the GUI:

- Navigate to **Settings > Access > Users and Policies**.
- In the **Directory Service** panel, select either the **Array Management** or **Data** button, then click the edit icon.
- Update the **URIs** field to use the ldaps:// scheme (e.g., ldaps://ldap.company.com:636) and click **Save**.
- To configure the root of trust, click **Edit** next to **CA Certificate** within the **Directory Service** panel. Paste the PEM-formatted certificate from your Certificate Authority and click **Save**. *(Note: The CA certificate is only used/applicable for the Array Management service, not the Data service).*

From the CLI:

- **Update the URI to LDAPS:** Modify the directory service URI using the **puredds setattr** command.
- **Command Syntax:** **puredds setattr --uri ldaps://<LDAP_SERVER>:<PORT> <SERVICE-NAME>**
- **Example:** **puredds setattr --uri ldaps://dc01.domain.com:636 management**
- **Verify the Configuration:**
- Run puredds list to ensure the URI successfully updated.

Default Value:

By default, the directory service URI is not configured. When configured, the URI scheme depends on the administrator's input; LDAP (plaintext) is permitted unless LDAPS is explicitly chosen.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

2.5 Ensure syslog servers use TLS with a configured CA root of trust (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray supports configuring remote syslog servers to receive a variety of different messages, including administrative and data audit records, session records, and alerts.

Everpure recommends the following:

- Configure all syslog servers to use TLS to protect traffic from inspection and tampering.
- Configure one or more certificate authorities as roots of trust for syslog servers.

Rationale:

Syslog messages for audits, sessions, etc. are important for detection and response pipelines. As such it is prudent to ensure they cannot be tampered with.

Some such information can also be considered sensitive or contain PII, and so avoiding disclosure of their contents is also important.

As such, proper roots of trust are important for ensuring the TLS authenticity cannot be compromised, and such TLS traffic cannot be intercepted.

Impact:

TLS syslog requires a syslog receiver (e.g., rsyslog, Splunk) configured to accept TLS connections on an appropriate port (typically TCP 6514). The receiver must present a valid TLS certificate, and certificate validation must be maintained. If the TLS handshake fails, log events may be dropped or buffered depending on the syslog implementation.

Audit:

To align with the security recommendations, verify that configured syslog servers use TLS and that a Certificate Authority (CA) certificate is configured as a root of trust for syslog communications.

From the GUI:

- Navigate to **Settings > System**.
- Locate the **Syslog Servers** panel.
- Verify that the URI for each configured server uses the `tls://` scheme.

From the CLI:

- Run the command `purelog syslog list`. Review the output to confirm the URI field uses the `tls://` scheme rather than `udp://` or `tcp://`.
- Run the command `purelog syslog global list --ca-certificate` to verify that a CA certificate is imported for authenticating syslog servers.

Remediation:

To align with the security recommendations, configure your syslog servers to use TLS encryption and import a CA certificate to authenticate the remote servers.

From the GUI:

- Navigate to **Settings > System**.
- In the **Syslog Servers** panel, remove any existing plaintext syslog entries.
- Enter the URI of your remote syslog server using the `tls://` scheme (e.g., `tls://10.10.10.10:6514`).
- Click the **Add** button to add the URI to the list of syslog server output locations.

From the CLI:

- **Delete the existing plaintext syslog server:**
- *Command Syntax:* `purelog syslog delete <SERVER_NAME>`
- **Add a TLS-encrypted syslog server:**
- *Command Syntax:* `purelog syslog create --uri tls://<SYSLOG_HOST>:<PORT> <NAME>`
- **Import the CA certificate for syslog:** Purity//FA's syslog agent uses this certificate to authenticate itself to the remote syslog servers.
- *Command Syntax:* `purelog syslog global setattr --ca-certificate`
- *Action:* Paste the PEM-formatted certificate at the interactive prompt.
- **Verify the new configuration:**
- *Command Syntax:* `purelog syslog list`

Default Value:

No syslog servers are configured by default. When configured by the administrator, the URI scheme is determined by the administrator's input; TLS is not enforced by default.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

2.6 Ensure the SMTP relay host is configured with STARTTLS encryption and authentication (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray supports configuring a relayhost for the simple mail transfer protocol (SMTP) for the purpose of ensuring email delivery for alert emails.

Everpure recommends the following:

- Configure an SMTP relayhost.
- Configure the starttls encryption mode for SMTP.
- Configure authentication for your SMTP relayhost, if it supports it.

Rationale:

SMTP relayhosts improve the reliability of email delivery, helping to avoid issues that can cause missed alerts. Enforcing TLS between FlashArray and the relayhost prevents tampering and disclosure of email contents.

Impact:

Enabling TLS for SMTP requires that the mail relay or SMTP gateway supports TLS. If the mail relay presents a certificate that FlashArray cannot validate, email delivery may fail. Verify SMTP TLS compatibility with your mail infrastructure before enabling.

Audit:

To align with the security recommendations, verify that an SMTP relay host is configured, it enforces TLS encryption (starttls), and authentication is utilized if supported by your relay host.

From the GUI:

- Navigate to Settings > System and locate the Alert Routing (Relay Host) panel.
- Verify that a Relay Host is configured.
- Verify that the Encryption Mode is set to starttls.
- If your relay requires authentication, verify that a Username is configured.

From the CLI:

- Display the current SMTP configuration by running the command `puresmtp list`.
- Review the output to verify the following:
 - A valid Relay Host is configured.
 - The Encryption Mode is set to starttls.
 - If your SMTP server requires it, the Username field is populated (indicating authentication is configured).

Remediation:

To align with the security recommendations, update your SMTP configuration to specify your relay host, enforce TLS encryption, and configure authentication credentials.

From the GUI:

- Navigate to Settings > System and locate the Alert Routing (Relay Host) panel.
- Enter your SMTP Relay Host address.
- Set the Encryption Mode to starttls.
- If authentication is required, enter the Username and Password.
- Click Save.

From the CLI:

- **Configure the relay host and enforce TLS:** Use the `puresmtp setattr` command to specify your server and set the encryption mode to starttls.
- **Command Syntax:** `puresmtp setattr --relay-host <HOST> --encryption-mode starttls`
- **Example:** `puresmtp setattr --relay-host smtp.mycompany.com --encryption-mode starttls`
- **Configure Authentication (if required):** If your SMTP server requires authentication, append the `--username` and `--password` flags.
- **Command Syntax:** `puresmtp setattr --username <USERNAME> --password`
- **Action:** Purity will prompt you interactively to enter and retype the password.

Default Value:

By default, no SMTP relay host is configured. When a relay host is configured, the encryption mode defaults to opportunistic TLS (blank string) and must be explicitly set to starttls to enforce encryption.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

2.7 Ensure SNMP, if enabled, uses SNMPv3 with SHA authentication and AES privacy (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray supports configuring the simple network management protocol (SNMP). An SNMP agent can be configured on the array, allowing external clients to query the array using SNMP for information such as performance metrics and array details.

SNMP managers can also be configured to receive alerts.

Everpure recommends that you do not utilize SNMP unless your environment requires it.

If SNMP is enabled, Everpure recommends the following:

- Utilize SNMPv3, not SNMPv2c.
- Configure an authentication passphrase with SHA as the authentication protocol. The authentication passphrase should be 8 characters or longer, and sufficiently complex.
- Configure a privacy passphrase with AES as the privacy protocol. The privacy passphrase should be 8 characters or longer, and sufficiently complex.

Rationale:

SNMP as a protocol is necessary in some environments, where retrieving metrics and configuration via a REST API may not be feasible, or where email or syslog delivery of alerts may not be available.

SNMPv2c has weak authentication, and should not be used.

When using SNMPv3, it is important to use strong passwords for authentication and privacy.

Impact:

Migrating from SNMP v2c to v3 requires updates to all monitoring tools and network management systems that poll the FlashArray. SNMP v3 configuration requires that both the FlashArray and the monitoring tool are configured with matching authentication and privacy credentials.

Audit:

To align with the security recommendations, verify that if SNMP is utilized, it is strictly configured for SNMPv3 with an authentication protocol of SHA (with a passphrase of 8 characters or more) and a privacy protocol of AES (with a passphrase of 8 characters or more).

From the GUI:

- Navigate to **Settings > System**.
- Locate the **SNMP** panel.
- Review the list of configured SNMP Managers and verify that the **Version** column is set to v3.
- Verify that the **Auth Protocol** is configured as SHA and the **Privacy Protocol** is configured as AES.

From the CLI:

- Run the command `purenmp list to display the configuration of the SNMP agent` and any SNMP managers.
- Review the output to verify the following for any configured manager or the localhost agent:
- Version is set to v3.
- Auth Protocol is set to SHA.
- Privacy Protocol is set to AES.

Remediation:

To align with the security recommendations, update your SNMP configuration to utilize SNMPv3 with strong authentication and privacy protocols, and ensure passphrases meet the 8-character minimum complexity requirement.

From the GUI:

- Navigate to **Settings > System**.
- In the **SNMP** panel, click the menu icon and select **Add SNMP Manager** (or click **Edit** for an existing manager).
- Complete the following fields in the dialog box:
- **SNMP Version:** Select v3.
- **User:** Enter the recognized User ID.
- **Auth Protocol:** Select SHA.
- **Auth Passphrase:** Enter a complex passphrase of at least 8 characters.
- **Privacy Protocol:** Select AES.
- **Privacy Passphrase:** Enter a complex passphrase of at least 8 characters.
- Click **Create** (or **Save**). *(Note: To secure the built-in **localhost** agent, click the Edit (pencil) icon next to it and apply the same v3, SHA, and AES settings).*

From the CLI:

- **Configure an SNMP Manager:** Create or update an SNMP manager to enforce v3, SHA, and AES using the `puresnmp create` or `puresnmp setattr` command.
- **Command Syntax:** `puresnmp create --host <HOST> --version v3 --user <USER> --auth-protocol SHA --auth-passphrase --privacy-protocol AES --privacy-passphrase <MANAGER_NAME>`
- **Action:** Purity will prompt you interactively to enter and retype the authentication and privacy passphrases. Ensure both are at least 8 characters long.
- **Secure the local agent:** Update the built-in localhost agent to require SNMPv3.
- **Command Syntax:** `puresnmp setattr --version v3 --user <USER> --auth-protocol SHA --auth-passphrase --privacy-protocol AES --privacy-passphrase localhost`

Default Value:

By default, no external SNMP managers or community strings are configured. A built-in SNMP agent named localhost exists and cannot be deleted or renamed, but it must be explicitly configured to communicate securely.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			

2.8 Ensure at least 3 NTP servers and an NTP symmetric key are configured (Automated)

Profile Applicability:

- Level 2

Description:

The network time protocol (NTP) allows time to be synchronized between devices on a network.

Everpure recommends the following:

- Configure at least 3 NTP servers.
- Configure an NTP symmetric key.

Note: The NTP symmetric key cannot be configured through the GUI. This can only be done through the CLI.

Rationale:

There are many security and data protection controls that rely on time. Properly checking the validity of certificates, short lived credentials, and other keys depends on proper time synchronization. Similarly there exist data protection features that rely on time.

As such, synchronization of time on your network is crucial for appropriate security behavior. It is therefore recommended that you configure multiple NTP servers for redundancy.

NTP symmetric keys are used for generating message authentication codes when synchronizing time. These prevent a malicious actor from intercepting and tampering with NTP messages.

FlashArray will ignore NTP messages after initial startup that substantially alter time, but in order to prevent any tampering with time by a bad network actor, Everpure recommends that you configure an NTP symmetric key.

Impact:

NTP symmetric key authentication requires that all configured NTP servers support and are configured with matching key IDs and keys. Misconfiguration may result in NTP authentication failures and loss of time synchronization. Time drift can cause authentication failures and log inconsistencies.

Audit:

To align with the security recommendations, verify that at least three NTP servers are configured for redundancy, and that an NTP symmetric key is configured to prevent tampering with time synchronization.

From the GUI:

- Navigate to **Settings > System**.
- Locate the **Time** panel and review the **NTP Servers** section.
- Verify that at least three NTP server addresses are listed.

From the CLI:

- Run the command `purearray list --ntp`.
- Review the output to verify that at least three NTP servers are configured.
- Review the same output to verify that an NTP symmetric key is configured.

Remediation:

To align with the security recommendations, configure at least three NTP servers and secure the communication using an NTP symmetric key.

From the GUI:

- Navigate to **Settings > System**.
- In the **Time** panel, locate the **NTP Servers** section.
- In the **New NTP Server(s)** text box, type the hostname or IP address of your NTP servers (you can enter multiple servers as comma-separated values).
- Click the **Add** button. Ensure you have added at least three servers.

From the CLI:

- **Configure at least three NTP servers:** Specify the servers using the `purearray setattr` command.
- **Command Syntax:** `purearray setattr --ntpserver <SERVER1>,<SERVER2>,<SERVER3>`
- **Example:** `purearray setattr --ntpserver ntp1.example.com,ntp2.example.com,ntp3.example.com`
- **Configure the NTP symmetric key:** Secure the NTP communication by setting a symmetric key using the `--ntp-symmetric-key` flag. (*Note: The key must not contain the "#" character and cannot be longer than 20 characters for an ASCII string or 64 characters for a hex-encoded string*).
- **Command Syntax:** `purearray setattr --ntp-symmetric-key <KEY_STRING>`

Default Value:

By default, the array time is synchronized to an NTP server operated by Pure Storage (time.purestorage.com). NTP symmetric key authentication is not configured by default.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.4 <u>Standardize Time Synchronization</u> Standardize time synchronization. Configure at least two synchronized time sources across enterprise assets, where supported.			

2.9 Ensure product diagnostic tests for environmental integrations are run periodically (Manual)

Profile Applicability:

- Level 1

Description:

For many environmental integrations mentioned in this section, there exists FlashArray functionality to detect that your configuration is still working.

Everpure recommends that you periodically run the product diagnostics tests for the following configurations:

- SAML
- LDAP
- Active Directory
- Syslog
- SMTP Email delivery to alert watchers
- SNMP delivery to SNMP managers
- NTP

Rationale:

Even if a configuration was correct initially, it is possible for it to cease functioning later due to changes in DNS, changes in the network, expiration or rotation of certificates for TLS, removal of credentials, or other similar issues.

Many of these configurations are crucial for security or for monitoring, and so verifying that they are functional ensures non-disrupted product functionality as well as that you will properly be alerted of other system events that may require attention.

Impact:

Periodic diagnostic testing has minimal impact on the array itself. Running tests against external integrations (SAML, LDAP/AD, syslog, SMTP, SNMP, NTP) generates authentication or connection attempts against those systems, so schedule them sensibly to avoid noise in downstream logs. A failed test indicates an integration has stopped functioning and should be investigated promptly, since it may mean security events are no longer being delivered.

Audit:

To align with the security recommendations, verify that an automated script or regular manual operational process is established to periodically execute product diagnostic tests for SAML, Directory Services (LDAP/AD), Syslog, SMTP Email Delivery, and NTP. This ensures these integrations have not ceased functioning due to DNS changes, certificate expirations, or network routing issues.

From the GUI:

- Request evidence of a standard operating procedure (SOP) demonstrating that administrators periodically run available connectivity tests.
- Navigate to **Settings > Access > Users and Policies**.
- In the **Directory Service** panel, verify that a test is periodically initiated.
- In the **SAML2 SSO** pane, verify that a test is periodically initiated.

From the CLI:

- Request evidence from your monitoring or automation teams that a script periodically connects to the array to execute configuration test commands (e.g., `pureso saml2 test`, `pureds test`, `purelog syslog test`, `purealert watcher test`, and `purearray test ntp`).

Remediation:

To align with the security recommendations, implement an automated script or a manual maintenance schedule to continuously verify that environmental integrations are fully functional.

From the GUI:

- Establish a periodic manual review process to execute available GUI diagnostic tests.
- **Test Directory Services:** Navigate to **Settings > Access > Users and Policies**. In the **Directory Service** panel, click **Test** to verify that URIs resolve and the array can bind to the LDAP/AD tree.
- **Test SAML2 SSO:** Navigate to **Settings > Access > Users and Policies**. In the **SAML2 SSO** pane, click **Test** (and specifically run the **E2E Test**) to verify the SP configuration, IdP connectivity, and verification certificate validity.

From the CLI:

- Establish a scheduled process (such as a cron job via the REST API or SSH) to periodically execute the following built-in diagnostic commands:
- **SAML2 SSO:** `puresso saml2 test <IDP-NAME>`
- **Directory Services:** `pureds test`
- **Syslog Servers:** `purelog syslog test` (or `purearray test syslogserver`)
- **SMTP Alert Watchers:** `purealert watcher test <EMAIL_ADDRESS>`
- **NTP Servers:** `purearray test ntp`

Default Value:

By default, Purity//FA does not automatically run scheduled diagnostic tests for external environmental configurations. Testing must be explicitly initiated manually by the administrator or via scheduled external scripts.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			

3 Protocol

This section describes the best practices pertaining to protocol security topics for Purity//FA 6.9, such as NFS export and SMB client policies, Active Directory integration, space quotas, space and performance monitoring and SMB audit policies.

3.1 Ensure NFS export policies restrict client access and enforce secure authentication (no wildcards, root squash, no sys auth) (Automated)

Profile Applicability:

- Level 1

Description:

NFS Export Policies are used to control access to any given file system export over any version of the NFS protocol. They can set properties such as permitted authentication mechanisms, allowance of root access from clients, and read-only vs. read-write based on client network identity.

They may utilize hostnames, IP addresses, subnet ranges, or wildcards as client identities. Any client that does not match any rule in an NFS export policy will be denied access to the exports to which the policy is attached. Everpure recommends the following:

- Do not use wildcard (*) clients in any NFS export policy rules.
- Do not permit sys authentication in any NFS export policy rules.
- Enable root squash for all clients in all NFS export policy rules.
- Constrain the allowed IP addresses to only those clients expected to need access to the exports for any given policy.
- Enable only **krb5p** authentication for clients where privacy is a concern. **krb5i** is recommended to be enabled for clients where data integrity is important but data privacy is not.

Rationale:

Use of wildcard clients means that no IP addresses will be denied access to a file system export. Even if using central authentication with kerberos, there is still a risk of some other compromise occurring within the environment. As such, Everpure recommends that you limit the IPs allowed to any access.

krb5p and **krb5i** both come with performance penalties in order to improve security. **krb5** provides only centralized identity and authentication, but if performance is paramount then it may see use. NFS sys authentication provides no security or identity controls, allowing for clients to act as any user, and should only be considered when there are strong guarantees on network security enforced outside of FlashArray. However, if such network controls are compromised, sys authentication provides no protection.

Root squash is important to configure in order to avoid privilege escalation on a client, or a rogue client, gaining elevated privileges on the export, as it prevents them from assuming root on the export as a result of having root access locally.

Impact:

Restricting NFS client access by IP may break access for clients that use dynamic IP addresses or that connect via NAT. Enabling root squash may break applications that require root access to NFS mounts. All restrictions should be tested in a non-production environment before being applied to production exports.

Audit:

To align with the security recommendations, verify that NFS export policies restrict access to specific client IPs (no wildcards), enforce root squashing, and utilize Kerberos (**krb5p** or **krb5i**) for authentication and privacy instead of the default AUTH_SYS.

From the GUI:

- Navigate to **Storage > Policies**.
- In the **Export Policies** panel, click the name of each active NFS policy to view its details.
- Review the **Rules** panel for the policy and verify the following:
- The **Client** field specifies explicit IP addresses or subnets (it is not set to * or 0.0.0.0/0).
- The **Access** field is set to root-squash.
- The **Security** field is set to **krb5p** (or **krb5i**), and auth_sys is not selected.
- The **Version** field includes **nfsv4** (which is required for Kerberos).

From the CLI:

- List all NFS export policies by running the command `purepolicy nfs list`.
- For each policy, inspect its rules by running the command `purepolicy nfs rule list <POLICY_NAME>`.
- Review the output to ensure:
- The Client column is restricted to specific subnets or IPs (and does not show *).
- The Access column is set to root-squash.
- The Security column is restricted to **krb5p** or **krb5i** (and does not include auth_sys).

Remediation:

To align with the security recommendations, update your NFS export policy rules to constrain client IPs, enforce root squash, and require Kerberos security.

From the GUI:

- Navigate to **Storage > Policies**.
- In the **Export Policies** panel, click the name of the NFS policy to modify.
- In the **Rules** panel, click the **+** (Create Rule) icon to add a new, secure rule.
(Note: Modifying existing NFS rules via the GUI is done by adding a new rule and removing the non-compliant one).
- Set the **Client** field to a specific IP subnet (e.g., 192.168.10.0/24).
- Select **root-squash** for the Access level.
- Select **NFSv4** for the Version.
- Select **krb5p** (or **krb5i**) for Security, and ensure **auth_sys** is unchecked.
- Click **Create** (or **Add**) to apply the rule.
- Delete the old, overly permissive rule by clicking the trash can (Remove Rule) icon next to it. (Note: Ensure that the **User Mapping Enabled** toggle is set to true in the policy's Details panel, as this is strictly required for Kerberos authentication).

From the CLI:

- **Create a secure rule:** Use the `purepolicy nfs rule add` command to create a rule with explicit client restrictions, root squash, and Kerberos security.
- **Command Syntax:** `purepolicy nfs rule add --client <SUBNET> --root-squash --version nfsv4 --security krb5p <POLICY_NAME>`
- **Example:** `purepolicy nfs rule add --client 192.168.10.0/24 --root-squash --version nfsv4 --security krb5p nfs_secure_policy`
- **Remove overly permissive rules:** Use the `purepolicy nfs rule remove` command to delete the old, non-compliant rule.
- **Command Syntax:** `purepolicy nfs rule remove --rule-name <RULE_NAME> <POLICY_NAME>`
- **Apply the policy to an export (if creating a new export):** Attach the secure policy to your managed directory using the `puredir export create` command.
- **Command Syntax:** `puredir export create --dir <FILESYSTEM:DIRECTORY> --policy <POLICY_NAME> <EXPORT_NAME>`
- **Example:** `puredir export create --dir FS1:Data --policy nfs_secure_policy DataShare`

Default Value:

By default, no NFS export policies are configured. When a rule is added to a policy without explicitly specifying options, the default settings allow unrestricted client access (*), enforce root-squash, enable read/write permissions (rw), use **nfsv3**, and use **auth_sys** security.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 <u>Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.			

3.2 Ensure SMB client policies require encryption, restrict client access, and disable anonymous access (Automated)

Profile Applicability:

- Level 1

Description:

SMB Client Policies are used to control access to any given file system export over any version of the SMB protocol. They can set properties such as SMB encryption requirements, and read-only vs. read-write based on client network identity.

They may utilize hostnames, IP addresses, subnet ranges, or wildcards as client identities. Any client that does not match any rule in an SMB client policy will be denied access to the exports to which the policy is attached. Everpure recommends the following:

- Do not use wildcard (*) clients in any SMB client policy rules.
- Require SMB encryption in all SMB client policy rules.
- Disable anonymous access in all SMB client policy rules.
- Constrain allowed IPs based on clients' expected to need access to the exports for any given policy.

Rationale:

Use of wildcard clients means that no IP addresses will be denied access to a file system export. Even if using central authentication with kerberos, there is still a risk of some other compromise occurring within the environment. As such, Everpure recommends that you limit the IPs allowed to any access.

SMB encryption ensures privacy and integrity, and is supported by all modern SMB clients. It requires SMB 3.0 or greater.

It does come with additional performance overhead, but it should not be made optional unless configuring clients where performance is paramount, or legacy clients that cannot support modern SMB versions. If it is not configured to be required, Everpure recommends that other controls outside of FlashArray be used to secure the network between FlashArray and its clients.

Anonymous access allows clients to access SMB exports without authentication. It substantially weakens security and can result in unintended information disclosure or tampering. As such it should be disabled.

Impact:

Restricting SMB client access by IP may break access for clients that use dynamic IP addresses or connect via NAT. Requiring SMB encryption adds minor cryptographic overhead and requires clients that support SMB 3.0 or greater; very old clients that cannot negotiate SMB 3 encryption will be unable to connect. Disabling anonymous access will break any workflow that depends on unauthenticated SMB access. Test all restrictions in a non-production environment before applying them to production exports.

Audit:

To align with the security recommendations, verify that SMB client policies restrict access to specific client IPs (no wildcards), enforce SMB encryption, and restrict anonymous access.

From the GUI:

- Navigate to **Storage > Policies**.
- In the **Export Policies** (or SMB Client Policies) panel, click the name of each active SMB policy to view its details.
- Review the **Rules** panel for the policy and verify the following:
 - The **Client** field specifies explicit IP addresses or subnets (it is not set to * or 0.0.0.0/0).
 - The **SMB Encryption Required** toggle is enabled (blue).
 - The **Anonymous Access Allowed** toggle is disabled (gray).

From the CLI:

- List all SMB client policies by running the command `purepolicy smb list`.
- For each policy, inspect its rules by running the command `purepolicy smb rule list <POLICY_NAME>`.
- Review the output to ensure:
 - The Client column is restricted to specific subnets or IPs (and does not show *).
 - The SMB Encryption Required attribute is enforced.
 - The Anonymous Access Allowed attribute is restricted/disabled.

Remediation:

To align with the security recommendations, update your SMB client policy rules to constrain client IPs, require SMB encryption, and ensure anonymous access remains disabled.

From the GUI:

- Navigate to **Storage > Policies**.
- In the **Export Policies** panel, click the name of the SMB policy to modify.
- In the **Rules** panel, click the **+** (Create Rule) icon to add a new, secure rule.
(Note: Modifying existing SMB rules via the GUI is done by adding a new rule and removing the non-compliant one).
- Set the **Client** field to a specific IP subnet (e.g., 192.168.10.0/24).
- Ensure the **SMB Encryption Required** toggle is enabled (blue).
- Ensure the **Anonymous Access Allowed** toggle is disabled (gray).
- Click **Create** (or **Add**) to apply the rule.
- Delete the old, overly permissive rule by clicking the trash can (Remove Rule) icon next to it.

From the CLI:

- **Create a secure rule:** Use the `purepolicy smb rule add` command to create a rule with explicit client restrictions and required encryption. (Note: Omitting the `anonymous access` flag restricts anonymous users by default).
- **Command Syntax:** `purepolicy smb rule add --client <SUBNET> --smb-encryption-required <POLICY_NAME>`
- **Example:** `purepolicy smb rule add --client 192.168.10.0/24 --smb-encryption-required smb_secure_policy`
- **Remove overly permissive rules:** Use the `purepolicy smb rule remove` command to delete the old, non-compliant rule.
- **Command Syntax:** `purepolicy smb rule remove --rule-name <RULE_NAME> <POLICY_NAME>`
- **Apply the policy to an export (if creating a new export):** Attach the secure policy to your managed directory using the `puredir export create` command.
- **Command Syntax:** `puredir export create --dir <FILESYSTEM:DIRECTORY> --policy <POLICY_NAME> <EXPORT_NAME>`
- **Example:** `puredir export create --dir FS1:Data --policy smb_secure_policy DataShare`

Default Value:

By default, no SMB client policies are configured. When an SMB rule is added without explicitly specifying options, the default settings allow unrestricted client access (*), disable anonymous access, and leave SMB encryption as optional (negotiation is enabled but data encryption is not enforced). SMB version 1.0 is deprecated and disabled by default due to security reasons.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 <u>Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.			
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

3.3 Ensure native Active Directory integration is used for NFS and SMB identity and authentication (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray supports native integration with Active Directory domains in order to enable LDAP lookups for authorization, and Kerberos authentication, for both NFS and SMB file access.

FlashArray does this by creating a computer account in the domain to represent itself and generate kerberos keys. A unique AD account may be created for each server on the array that needs one.

Everpure recommends that FlashArray's native Active Directory integration be configured in all environments where Active Directory provides identity, authentication, and authorization for NFS and SMB clients.

Rationale:

FlashArray also supports configuring an LDAP directory service, or NIS, for use with NFS for identity and authorization. It also supports manual uploading of kerberos keys to be used for authentication. However, each of these has security weaknesses when compared with native Active Directory integration.

While the LDAP directory service can provide the same level of TLS protection of traffic, its authentication relies on a bind username and password, with simple authentication.

Comparatively, native Active Directory integration allows the array to represent itself with a computer account and authenticate to the domain using kerberos. No raw passwords are ever stored on the array. This allows for stronger authentication and identity.

Impact:

AD join failures — due to password expiry for the service account, network connectivity issues, or DNS misconfigurations — can prevent all SMB clients from accessing file data. The AD join should be monitored and the service account should be excluded from password expiry policies with appropriate compensating controls.

Audit:

To align with the security recommendations, verify that FlashArray file services are natively integrated with an Active Directory domain to enable secure Kerberos authentication and strong identity authorization for SMB and NFS clients.

From the GUI:

- Navigate to **Storage > Servers** and click the name of your file server.
- Locate the **Remote Directory Service** panel.
- Verify that the Active Directory configuration is present and actively displays the correct domain and computer name.

From the CLI:

- Check the Active Directory domain join status by running the command `puread account list`.
- Review the output to verify that your file server's AD account is listed and the Domain field is correct.

Remediation:

To align with the security recommendations, join the FlashArray file server to your Active Directory domain.

From the GUI:

- Navigate to **Storage > Servers** and click your file server to access its settings.
- In the **Remote Directory Service** panel, click the Edit Configuration icon to the right and select **Active Directory**.
- In the Configure Remote Directory Service window, enter a **Name**, the **Domain DNS Name**, and the **Computer Name** for the array.
- Enter the **AD User** and **AD Password** for an Active Directory account with permission to create a new computer account (or select the **Use Existing Account** toggle if pre-created by your AD admin).
- Ensure **TLS Mode** is set to required.
- Click **Create** to apply the configuration and join the domain.

From the CLI:

- Join the file server to Active Directory using the `puread account create` command.
- *Command Syntax:* `puread account create --domain <DOMAIN> --computer-name <COMPUTER_NAME> <NAME>`
- *Example:* `puread account create --domain sales.local --computer-name SalesDocs server1::SalesAD` (Note: The CLI will prompt interactively for the Active Directory administrator credentials to perform the join; Purity//FA does not store these credentials).
- Verify the configuration by running the `puread account list` command.

Default Value:

Active Directory integration is not configured by default. It is strictly required in order to provide SMB file services.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 <u>Centralize Account Management</u> Centralize account management through a directory or identity service.			
v8	6.7 <u>Centralize Access Control</u> Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.			

3.4 Ensure a hard-limit quota policy is enforced on the root managed directory of every file system (Automated)

Profile Applicability:

- Level 2

Description:

FlashArray supports configuring quota policies in order to enforce space consumption limits on directories. These allow you to limit the total amount of space any directory and its child files and directories can consume.

Quota policies can be configured to use a soft limit, meaning they only alert when space exceeds the limit, or enforce a hard limit, meaning that new writes to the directory will be blocked when it is detected that the limit has been exceeded.

Everpure recommends that you configure a quota policy that enforces a hard limit on the root managed directory for every file system.

Rationale:

When strong security is configured to prevent malicious destruction of data, it also creates the risk that a malicious actor can write junk data to fill up a storage array, causing a system-wide outage.

- Enforcing space limits ensures that even if a malicious actor gains access to one directory, they cannot consume all the space on the system.
- Enforcing a space limit on the root directory of every file system ensures that, regardless of configurations and exports of sub-directories, that file system will not be able to consume all of the space on the system.

Impact:

When a quota is reached, write operations to the affected directory will fail with a disk-full error, which may cause application errors or backup failures. Quota limits should be set with sufficient headroom to avoid unexpected interruptions, and quota utilization should be monitored and alerted on before the limit is reached.

Audit:

To align with the security recommendations, verify that an enforced (hard limit) directory quota policy is actively configured and applied to the root managed directory of every file system. This ensures that no single file system can be maliciously filled to consume the entire storage array.

From the GUI:

- Navigate to **Storage > Policies** and locate the **Quota Policies** panel.
- Click the name of a quota policy and review the **Rules** panel to ensure the **Enforced** attribute is active (which creates a hard limit rather than a soft notification).
- Navigate to **Storage > File Systems** and select your file system.
- Locate the **Directory Quotas** panel. Verify that a quota policy with an enforced hard limit is attached to the root managed directory (e.g., fs1:root).

From the CLI:

- Run the command `puredir quota list` to display all directories with an attached quota policy. Verify that the root managed directories for your file systems are listed.
- Run the command `purepolicy quota rule list` to inspect the rules for the attached policies. Verify that the **Enforced** column is set to **True** and an appropriate Quota Limit is established.

Remediation:

To align with the security recommendations, create a quota policy with an enforced hard limit and attach it to the root managed directory of each file system.

From the GUI:

- Navigate to **Storage > Policies**.
- In the **Quota Policies** panel, click the **+** (Create Policy) icon.
- In the pop-up window, enter a **Name** for the policy.
- In the rules section, specify the **Quota Limit** (e.g., 5T).
- Click the **Enabled** toggle icon next to **Enforced** so that it turns blue. This ensures new writes are blocked when the limit is exceeded. Click **Create**.
- Click the name of your newly created quota policy.
- In the **Members** panel, click the menu icon and select **Add Member**.
- Select the root directory (e.g., fs1:root) of your file system and click **Add** to apply the policy.

From the CLI:

- **Create the quota policy:**
- *Command Syntax:* `purepolicy quota create <POLICY_NAME>`
- *Example:* `purepolicy quota create root_hard_quota`
- **Add an enforced rule to the policy:** Add a rule with your desired size limit and ensure the `--enforced` flag is used.
- *Command Syntax:* `purepolicy quota rule add --quota-limit <SIZE> --enforced <POLICY_NAME>`
- *Example:* `purepolicy quota rule add --quota-limit 5T --enforced root_hard_quota`
- **Attach the policy to the root directory:** Apply the policy to the root managed directory of your file system.
- *Command Syntax:* `purepolicy quota add --dir <FILESYSTEM>:root <POLICY_NAME>`
- *Example:* `purepolicy quota add --dir FS1:root root_hard_quota`

Default Value:

By default, no directory quotas are configured. Directories can consume available array capacity without restriction.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			

3.5 Ensure space consumption and performance are monitored for anomalies (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray offers capabilities for monitoring space consumption, data reduction, and performance across a variety of axes.

For performance, these include, but are not limited to:

- Array-wide
- By directory
- By volume
- By volume group
- By host
- By host group

For space, these include, but are not limited to:

- Array-wide
- By directory
- By volume
- By volume group
- By host
- By host group

Everpure recommends the following:

- Monitor the space consumption at various levels over time for anomalies such as rapid reduction in space utilization or data reduction.
- Monitor performance at various levels over time for anomalies such as spikes in reads or writes by a specific client or user.

Rationale:

Sudden trends resulting in reduction in the data reduction ratio can indicate potential Ransomware attacks. Rapid reductions in utilized space can indicate malicious deletion of data.

An unexpected spike in read bandwidth by a specific client, when compared to space utilization, can indicate potential exfiltration of data.

Other similar anomalies in space and performance monitoring can indicate rogue actors having gained access to some part of the storage system.

Impact:

Continuous monitoring requires integration with external monitoring infrastructure (SNMP, syslog, Pure1, or a third-party monitoring tool). The overhead on the FlashArray itself is minimal, but the receiving infrastructure must be sized to handle the volume of metrics data.

Audit:

To align with the security recommendations, verify that space consumption and I/O performance are continuously monitored at the array, file system, and directory levels to detect potential anomalies such as ransomware encryption, data exfiltration, or malicious deletion.

From the GUI:

- Navigate to **Analysis > Performance** to review the array-wide and volume-level I/O metrics (Latency, IOPS, and Bandwidth) for any unexpected spikes or anomalies.
- Navigate to **Analysis > Capacity** to review current array capacity utilization and trends.
- Navigate to **Storage > File Systems** to verify the capacity utilization of specific file systems.

From the CLI:

- Check file system / directory space usage by running the command `puredir list --space`.
- Check real-time or historical array performance metrics by running the command `purearray monitor` (or `purearray monitor --historical <TIME>`).
- Check array-wide space usage by running the command `purearray list --space`.

Remediation:

To align with the security recommendations, implement a regular monitoring process using the built-in Analysis dashboards or automated CLI scripts to track capacity and performance trends.

From the GUI:

- Establish a continuous manual monitoring routine using the **Analysis > Capacity** and **Analysis > Performance** pages to monitor capacity trends and bandwidth/IOPS metrics.
- Ensure you have configured syslog servers or email alert watchers (as covered in earlier sections) so that built-in capacity alerts (e.g., warnings when storage consumption reaches 90% of usable capacity) are proactively pushed to your monitoring teams.

From the CLI:

- Implement a scheduled automation script to periodically pull space and performance metrics to an external monitoring system using the following commands:
- *Array Space*: `purearray list --space`
- *Array Performance*: `purearray monitor`
- *File System / Directory Space*: `puredir list --space`

Default Value:

Performance and capacity data collection is always active on the FlashArray, maintaining a rolling one-year history of data by default. External forwarding of these metrics to third-party monitoring systems is not configured out of the box.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.11 <u>Conduct Audit Log Reviews</u> Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.			

3.6 Ensure SMB audit policies with syslog and file log targets are attached to production file systems (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray supports creation of one or more audit policies for enabling audit of operations over the SMB data protocol.

These audit policies may be used to send audit records to remote syslog servers for monitoring. Everpure recommends the following:

- Configure at least 1 syslog server and 1 directory as log targets among your audit policies for SMB.
- Configure at least 1 audit policy with a syslog log target, attached to each file system that stores production data and enables the SMB protocol for access.
- Configure at least 1 audit policy with a file log target, attached to each file system that stores production data and enables the SMB protocol for access.
- Instruct administrative users for each file system SMB export to configure appropriate SACLs to ensure proper auditing.

Rationale:

Auditing access and operations to file data over the SMB protocol allows for detection of unexpected behavior by SMB clients, which can indicate malicious actors gaining unintended access to an export.

Sending of audit records to a remote syslog server allows for logs across systems to be aggregated and analyzed centrally. This allows for better analysis of patterns spanning across systems and management of retention for detection and response, but it can also lead to dropped logs due to network bandwidth limitations.

Locally stored audit records do not have a dependency on the network, and can be more reliable, but can be more difficult to integrate into real-time analysis pipelines since they would need to be periodically pulled.

As such, it is recommended that both remote syslog and local log targets be utilized, with appropriate retention based on your environment. This enables central aggregation of audit records for detection and response, while also ensuring that there is a robust local backup of logs in case of a network or syslog server outage.

Which files, directories, and operations within a file system are audited is determined by SACLs, and which users can set SACLs is determined by the GPOs in your Active Directory domain. So users in the appropriate groups must be instructed to configure SACLs appropriately in order to ensure auditing is enabled.

Impact:

Enabling SMB file auditing introduces several operational and resource impacts. Sending continuous file access logs to a remote syslog server consumes network bandwidth and requires significant long-term storage capacity and processing power on the receiving SIEM. Utilizing a local managed directory as a file log target also consumes physical storage capacity on the FlashArray.

Audit:

To align with the security recommendations, verify that at least one syslog server and one local directory are configured as file log targets, and that an active audit policy is attached to all file systems utilizing SMB.

From the GUI:

- Navigate to **Settings > System** to verify that a remote syslog server is configured (in the **Syslog Servers** panel) and a local directory is configured (in the **File Log Targets** panel).
- Navigate to **Storage > Policies**.
- Scroll to the **Audit Policies** panel and select your configured audit policy.
- Review the **Details** panel to verify that both the local directory and syslog server are listed as log targets.
- Review the **Members** panel to verify that the policy is attached to the appropriate production managed directories. *(Note: Verifying that proper System Access Control Lists (SACLs) are applied to the SMB share must be done externally via Windows MMC or similar tools, as this is not visible in the Purity GUI).*

From the CLI:

- Run the commands `purelog file list` and `purelog syslog list` to verify that local and remote log targets exist.
- Run the command `purepolicy audit file list` to verify that an audit policy exists and its Enabled status is set to True.
- Review the policy members by running `purepolicy audit file list --member` to ensure the policies are successfully attached to the correct source managed directories.

Remediation:

To align with the security recommendations, establish file log targets, create an audit policy, attach it to your production managed directories, and externally configure SACLS for SMB exports.

From the GUI:

- **Create the File Log Target:** Navigate to **Settings > System**. In the **File Log Targets** panel, click the **+** (Create) icon. Provide a name, select an empty managed directory to store the logs, configure a retention policy (Keep For or Keep Size), and click **Create**.
- **Create the Syslog Target** (*if not already configured*): In the **Syslog Servers** panel, add your remote syslog server URI.
- **Create the Audit Policy:** Navigate to **Storage > Policies**. In the **Audit Policies** panel, click the **+** (Create Policy) icon. Provide a name, ensure the **Enabled** toggle is active, select the File Log Target and Syslog Target you created in the **Log Targets** prompt, and click **Create**.
- **Attach the Policy to Directories:** Click your newly created audit policy to open it. In the **Members** panel, click the menu icon, select **Add member...**, select your production managed directories, and click **Add**.
- **Configure SACLS:** Instruct your file server administrators to connect to the SMB export using a Windows client and utilize Windows MMC to configure the SACLS that dictate which file operations generate audit events.

From the CLI:

- **Create Log Targets:**
- *Command Syntax:* `purelog file create --dir <FILESYSTEM:DIRECTORY> -
-keep-for <PERIOD> <NAME>`
- *Command Syntax:* `purelog syslog create --uri tls://<HOST>:<PORT>
<SYSLOG_NAME>`
- **Create the Audit Policy:**
- *Command Syntax:* `purepolicy audit file create --targets
<TARGET1>,<TARGET2> <POLICY_NAME>`
- *Example:* `purepolicy audit file create --targets
local_dir_target,syslog_target smb_audit_policy`
- **Attach to Directories:**
- *Command Syntax:* `purepolicy audit file add --dir
<FILESYSTEM:DIRECTORY> <POLICY_NAME>`
- *Example:* `purepolicy audit file add --dir FS1:Data smb_audit_policy`
- **Enable the Policy:**
- *Command Syntax:* `purepolicy audit file enable <POLICY_NAME>`
- **Configure SACLS:** Establish appropriate SACLS externally using Windows MMC.

Default Value:

By default, no file log targets or file audit policies are configured on the FlashArray.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.14 <u>Log Sensitive Data Access</u> Log sensitive data access, including modification and disposal.			●
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●

4 Data Protection

This section describes the best practices pertaining to data protection security topics for Purity//FA 6.9, such as eradication configuration, protection groups and block SafeMode, snapshot policies, default protection, array connection and replication, snapshot offload targets and replication status monitoring.

4.1 Ensure manual eradication is disabled and the eradication delay is at least 8 days for production data (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray possesses a variety of configurations, such as realms and pods, that pertain to data protection.

These configurations can have their data eradication properties configured. Everpure recommends the following:

- Disable manual eradication for all pods, realms, or arrays that will contain production data.
- Set the eradication delay for objects that cannot be manually eradicated to be at least 8 days.

Rationale:

In case of administrative compromise, it is important to safeguard against manual erasure of all system data and backups.

Disabling manual eradication of important data is a crucial step towards preventing such compromise.

For containers such as pods, disabling manual eradication prevents its contents from being manually eradicated.

When manual eradication is disabled for a pgroup, both the volumes and snapshots associated with that pgroup will not be able to be manually eradicated.

When manual eradication of an object is disabled, it may be destroyed (i.e. put into the recycling bin), but will not be able to be eradicated and fully erased until the configured eradication delay has elapsed. It is important to ensure that this delay is reasonably long to prevent quick deletion of data on a compromised system.

Separate delays can be configured for objects that can be manually eradicated and those that cannot; ensuring that those that cannot be manually eradicated have a delay of at least 8 days ensures a reasonable window of protection.

This eradication delay is measured in system uptime, not wall time. As such, this eradication delay is resistant to attempts at NTP tampering.

Impact:

Disabling manual eradication and extending the eradication delay to at least 8 days removes an administrator's ability to instantly free up physical storage capacity by permanently deleting destroyed volumes, pods, or snapshots. If the array experiences unexpected rapid data growth and reaches full capacity, administrators will be strictly prevented from manually eradicating data in the recycling bin to recover space. This condition could lead to a halt in replication and degraded host I/O until the eradication pending period naturally expires or additional physical storage is added. Furthermore, once the disabled eradication delay is set and SafeMode is enabled, the delay cannot be decreased, and SafeMode cannot be unlocked without explicit authorization and intervention from Everpure Technical Services.

Audit:

To align with the security recommendations, verify that the manual eradication of data is disabled (via SafeMode) and that the eradication delay for protected objects is set to a minimum of 8 days.

From the GUI:

- Navigate to **Settings > System**.
- Locate the **Eradication Configuration** panel.
- Verify that the **Disabled Delay** is set to at least 8 days (or higher).
- Verify that the **Manual Eradication** column does not read all-enabled (it should read all-disabled or partially-disabled to indicate SafeMode is actively protecting objects from being manually destroyed).

From the CLI:

- Run the command `purearray eradication-config list` to view the **eradication delay values** and manual eradication status.
- Review the output to ensure the Disabled Delay is at least 8d and the Manual Eradication status is not all-enabled.

Remediation:

To align with the security recommendations, extend the disabled eradication delay to at least 8 days and engage SafeMode retention locks to disable manual eradication.

From the GUI:

- Navigate to **Settings > System**.
- In the **Eradication Configuration** panel, click the edit icon in the upper right corner.
- Set the **Disabled Delay** to at least 8 days (14 days is mathematically recommended to provide a 2-week buffer).
- Click **Save**.
- To actively disable manual eradication, you must enable SafeMode retention locks on your data. Navigate to **Protection > Protection Groups**, click the name of your protection group to open its details, and in the **SafeMode** pane, click the edit icon to ratchet the retention lock. *(Note: Array-wide SafeMode enrollment requires contacting Everpure Technical Services with at least two administrators and PIN codes).*

From the CLI:

- **Set the Eradication Delay:** Configure the disabled delay using the `purearray eradication-config setattr` command.
- **Command Syntax:** `purearray eradication-config setattr --disabled-delay <DAYS>d`
- **Example:** `purearray eradication-config setattr --disabled-delay 14d`
- **Disable Manual Eradication:** Enforce manual eradication prevention by ratcheting the SafeMode retention lock on your protection groups using the `puregroup retention-lock ratchet` command.
- **Command Syntax:** `puregroup retention-lock ratchet <PGROUP>`
- **Example:** `puregroup retention-lock ratchet pgroup1`

Default Value:

By default, the Disabled Delay (eradication delay for SafeMode-protected objects) is 8 days, and the Enabled Delay (for non-protected objects) is 1 day. Manual Eradication is all-enabled by default because SafeMode is not enabled and retention locks are unlocked out of the box.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	11.3 <u>Protect Recovery Data</u> Protect recovery data with equivalent controls to the original data. Reference encryption or data separation, based on requirements.			

4.2 Ensure production volumes and hosts are protected by ratcheted (SafeMode) protection groups with daily snapshots (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray allows for protection groups (pgroups) to be created. These pgroups can be attached to hosts and volumes in order to schedule the creation and replication of snapshots for the purpose of data protection.

Additionally, pgroups may be ratcheted to enable a feature known as SafeMode. Once a pgroup has its retention lock set to ratcheted, the protection that it provides can only be increased, not decreased. So it may be attached to more things, and made to make more snapshots; but it cannot be detached from its members or changed to take and retain fewer snapshots.

Administrators of the array will not be able to un-ratchet the retention lock and reduce protection without involving Everpure Support. Everpure recommends the following:

- Associate all volumes with at least one pgroup, or add them to a volume group with an associated pgroup.
- Associate all hosts with at least one pgroup, or add them to a host group with an associated pgroup.
- Ratchet all pgroups that will be associated with production data, in order to disable manual eradication of the associated data.
- Configure pgroups to create at least 1 snapshot per day.
- Configure pgroups to replicate at least 1 snapshot per day.
- Configure pgroups to retain each snapshot for at least 7 days.

Rationale:

Automatically, periodically creating immutable backups is an important aspect of data protection. Because FlashArray snapshot contents are immutable, they cannot be targeted for encryption by threats such as Ransomware.

Ratcheting the pgroup ensures that protection cannot be reduced in the case of administrative compromise, and disabling manual eradication prevents data erasure by a compromised administrator.

- In order to mitigate the impact of an attack on any host or volume, every host or volume on a FlashArray should have at least one pgroup automating the creation of backups, either directly or indirectly via a group.
- In order to mitigate the impact of a physical system being destroyed or tampered with, replicating backups automatically is highly recommended.

Snapshots can be used to restore the prior state of a volume that has been tampered with, and so it is recommended that at least 1 snapshot be taken daily. Because it may take some time to discover tampering, it is recommended that they be retained for at least 7 days.

Impact:

Enabling SafeMode (ratcheting) on a protection group completely removes local administrative authority to reduce data protection. Once ratcheted, administrators absolutely cannot destroy the protection group, manually eradicate its snapshots to free up space, decrease the snapshot/replication frequency, decrease the retention period, or remove members and targets. Un-ratcheting the protection group to perform any of these actions requires explicit authorization and intervention from Everpure Technical Services, which involves at least two authorized administrators and PIN codes.

Additionally, SafeMode retention lock is not supported for protection groups that contain host members, host group members, or offload targets. To secure these environments, you must create a separate ratcheted protection group that specifically targets the underlying volumes instead. Finally, enforcing a schedule that creates and replicates at least one snapshot per day and retains them for a minimum of 7 days will continuously consume physical storage capacity on both the source and target arrays.

Audit:

To align with the security recommendations, verify that production volumes are protected by a protection group, that the protection group enforces SafeMode (ratcheted), and that snapshots are scheduled at least daily and retained for a minimum of 7 days. *(Note: SafeMode retention lock cannot be enabled on protection groups containing hosts, host groups, or offload targets; you must explicitly target the underlying volumes).*

From the GUI:

- Navigate to **Protection > Protection Groups**.
- Click on a source protection group to view its details.
- Review the **Members** pane to verify that production volumes are included (and ensure no hosts, host groups, or offload targets are included).
- Review the **SafeMode** pane and verify that the **Retention Lock** status is set to ratcheted.
- Review the **Snapshot Schedule** and **Replication Schedule** panes to verify that they are enabled, configured to run at least once every 24 hours (1 day), and that the retention strategy keeps snapshots for at least 7 days.

From the CLI:

- Run the commands `purevol list --protect` (and `purehost list --protect`) to verify that your production workloads are actively associated with a protection group.
- Run the command `purepgroup list --retention-lock` to verify the SafeMode status is ratcheted for your production protection groups.
- Run the commands `purepgroup list --schedule` and `purepgroup list --retention` to verify that the snapshot and replication frequencies are at least daily and retained for at least 7 days.

Remediation:

To align with the security recommendations, create a volume-based protection group, establish daily snapshot and replication schedules with at least 7 days of retention, and ratchet the group to enable SafeMode.

From the GUI:

- Navigate to **Protection > Protection Groups**.
- In the **Source Protection Groups** panel, click the **+** (Create Protection Group) icon, enter a name, and click **Create**.
- Click on the newly created protection group to open its details.
- In the **Members** pane, click the menu icon, select **Add...**, select your production volumes, and click **Add**.
- In the **Snapshot Schedule** and **Replication Schedule** panes, click the Edit (pen and paper) icon. Toggle the schedule to **Enabled** (blue), configure it to create/replicate a snapshot at least every 1 days (or more frequent), and configure the retention to retain snapshots for at least 7 days. Click **Save**.
- In the **SafeMode** pane, click the edit icon and click the **Ratcheted** toggle button to enable (blue) the SafeMode feature. *(Note: Once ratcheted, a protection group cannot be unlocked without explicit authorization and intervention from Everpure Technical Services).*

From the CLI:

- **Create the protection group:**
- *Command Syntax:* `purepgroup create <PGROUP>`
- **Add volume members:**
- *Command Syntax:* `purevol add --pgroup <PGROUP> <VOLUMES>`
- **Configure the schedules (at least daily):**
- *Command Syntax:* `purepgroup schedule --snap-frequency 1d --replicate-frequency 1d <PGROUP>`
- **Configure the retention (at least 7 days):**
- *Command Syntax:* `purepgroup retain --all-for 1d --per-day 1 --days 7 <PGROUP>`
- **Enable the schedules:**
- *Command Syntax:* `purepgroup enable <PGROUP>`
- **Ratchet the protection group to enable SafeMode:**
- *Command Syntax:* `purepgroup retention-lock ratchet <PGROUP>`

Default Value:

By default, SafeMode retention lock is unlocked for protection groups. When a protection group's schedule is enabled without explicit customization, it defaults to generating snapshots every 1 hour, replicating every 4 hours, and retaining all snapshots for 1 day, followed by retaining 4 snapshots per day for 7 additional days.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	11.2 <u>Perform Automated Backups</u> Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data.			
v8	11.3 <u>Protect Recovery Data</u> Protect recovery data with equivalent controls to the original data. Reference encryption or data separation, based on requirements.			

4.3 Ensure an enabled snapshot policy taking at least one daily snapshot is attached to every directory (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray supports creating snapshot policies for automatically creating, managing, and deleting immutable snapshots of FlashArray directories. These policies can be additionally used to replicate file snapshots.

Everpure recommends the following if you have any file systems on the system:

- Attach at least one enabled snapshot policy to each directory.
- Configure snapshot policies to create at least 1 snapshot per day.
- Configure snapshot policies to retain each snapshot for at least 7 days.

Rationale:

Automatically, periodically creating immutable backups is an important aspect of data protection. Because FlashArray snapshot contents are immutable, they cannot be targeted for encryption by threats such as Ransomware.

In order to mitigate the impact of an attack on any export, every file system on a FlashArray should have at least one snapshot policy.

Snapshots can be used to restore the prior state of a file system that has been tampered with. Everpure recommends that at least 1 snapshot be taken daily and because it may take some time to discover tampering, that the snapshots be retained for at least 7 days.

Impact:

Enforcing a schedule that creates and retains daily file snapshots for at least 7 days will continuously consume physical storage capacity on the FlashArray. Because snapshots are immutable, the storage blocks associated with modified or deleted files within the directory cannot be reclaimed by the system to free up space until the covering snapshot's retention period expires. Additionally, modifying an existing policy's rules can occasionally lead to unexpected immediate storage consumption, as the scheduler may trigger additional snapshots out-of-cycle to fulfill a partially complete protection plan.

Audit:

To align with the security recommendations, verify that an active snapshot policy is attached to your production directories, ensuring that immutable snapshots are taken at least daily and retained for a minimum of 7 days to protect against ransomware and accidental deletion.

From the GUI:

- Navigate to **Protection > Policies**.
- In the **Snapshot Policies** panel, verify that a snapshot policy exists and its **Enabled** status is set to true.
- Click the name of the policy to view its details.
- Review the **Rules** panel and verify that the **Create 1 snapshot every** frequency is 1d (or more frequent) and the **And keep for** retention period is at least 7d (or 1w or longer).
- Review the **Members** panel to verify that all production directories are listed and actively attached to the policy.

From the CLI:

- Run the command `purepolicy snapshot rule list` to verify the configured rules on your snapshot policies.
- Review the output to ensure the frequency (every) is at least daily (1d) and the retention (keep_for) is at least 7 days (7d or 1w).
- Run the command `purepolicy snapshot list --member to view all configured snapshot policies and verify that your production managed directories are successfully attached to them.`

Remediation:

To align with the security recommendations, establish a snapshot policy that takes daily snapshots with a 7-day retention period, and attach it to your file system managed directories.

From the GUI:

- Navigate to **Protection > Policies**.
- In the **Snapshot Policies** panel, click the **+** (Create Policy) icon. Provide a name, ensure the **Enabled** toggle is active (blue), and click **Create**.
- Click on the newly created policy name to open its details.
- In the **Rules** panel, click the **+** (Create Rule) icon (or menu icon > Create...) to add a new rule.
- Set **Create 1 snapshot every** to 1d (or a shorter interval like 12h).
- Set **And keep for** to 1w (or 7d or a longer duration like 30d).
- Provide a **Client Name** (e.g., daily) which will be visible to users recovering files, then click **Add**.
- In the **Members** panel, click the menu icon, select **Add Member...**, select your managed directories, and click **Add** to attach the policy.

From the CLI:

- **Create the Policy:** Create a new snapshot policy using the `purepolicy snapshot create` command.
- *Command Syntax:* `purepolicy snapshot create <POLICY_NAME>`
- *Example:* `purepolicy snapshot create data_snap`
- **Add a Compliant Rule:** Add a rule configuring the frequency (`--every`), retention (`--keep-for`), and client name (`--client-name`).
- *Command Syntax:* `purepolicy snapshot rule add --every <FREQUENCY> --keep-for <RETENTION> --client-name <NAME> <POLICY_NAME>`
- *Example:* `purepolicy snapshot rule add --every 1d --keep-for 7d --client-name daily data_snap`
- **Attach to Directories:** Attach the policy to your file system directories using the `puredir snapshot add` command.
- *Command Syntax:* `puredir snapshot add --policy <POLICY_NAME> <FILESYSTEM:DIRECTORY>`
- *Example:* `puredir snapshot add --policy data_snap FS1:Data`

Default Value:

By default, there are no snapshot policies configured for file systems out of the box, and no automated scheduled snapshots are taken for directories.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	11.2 <u>Perform Automated Backups</u> Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data.			
v8	11.3 <u>Protect Recovery Data</u> Protect recovery data with equivalent controls to the original data. Reference encryption or data separation, based on requirements.			

4.4 Ensure default protection is configured at the array level and for every pod (Automated)

Profile Applicability:

- Level 1

Description:

FlashArray allows the array and its pods to have default protection configured.

This allows you to configure pgroups that will be automatically associated with any volumes created within the pod or the array. This can be used to ensure that all block data has some level of data protection by default.

Everpure recommends the following if you intend to place any volumes on the system:

- Configure at least 1 pgroup as the default protection for every pod on the system, and at the array level.
- Any pggroups configured as default protection for containers that will have production data should have a ratcheted retention lock, with manual eradication disabled.

Rationale:

In case of administrative compromise, it is important to safeguard against manual erasure of all system data and backups.

Default protection ensures that you do not need to take extra steps to achieve a baseline protection of block data. It reduces the risk of user error causing a lapse in data protection.

It is also important to ensure that the default protection is reasonably strong, which is why it is recommended to ratchet the default protection for any production data, ensuring that it cannot be weakened and it disables manual eradication of the protected data.

When manual eradication of file is disabled, file systems and snapshots may be destroyed (i.e. put into the recycling bin), but will not be able to be eradicated and fully erased until the configured eradication delay has elapsed. This applies to all snapshots, not just those created by the safemode policy.

This eradication delay is measured in system uptime, not wall time. As such, this eradication delay is resistant to attempts at NTP tampering.

Impact:

Enforcing default protection using a ratcheted protection group ensures that every newly created or copied volume is immediately subjected to SafeMode retention locks. Consequently, administrators will be strictly prevented from manually eradicating any newly created volume or its snapshots to quickly recover physical storage space, which could lead to capacity exhaustion issues if a large volume was provisioned or copied in error. Furthermore, once a ratcheted protection group is set as the default, you cannot opt out of or remove that group from the default protection list without explicit authorization and intervention from Everpure Technical Services.

Audit:

To align with the security recommendations, verify that at least one protection group is configured as the default protection for every pod and the array root, and that they enforce SafeMode (ratcheted) to prevent manual eradication of newly provisioned volumes.

From the GUI:

- Navigate to **Protection > Array**.
- Scroll to the **Default Protection** panel.
- Verify that a protection group is listed for the array root (denoted by - in the Container Name column) and for every configured pod.
- Navigate to **Protection > Protection Groups**.
- Click on the protection groups listed as defaults to view their details.
- In the **SafeMode** pane, verify that the **Retention Lock** status is set to ratcheted.

From the CLI:

- Run the command `purearray default-protection list to view the default protection group lists for the array root` (denoted by - in the Container Name column) and all pods.
- Run the command `purepgroup list --retention-lock to verify that the SafeMode status is ratcheted` and manual eradication is disabled for the protection groups assigned as defaults.

Remediation:

To align with the security recommendations, assign a ratcheted protection group to the array root and all pods so that newly provisioned data receives baseline SafeMode protection automatically.

From the GUI:

- Navigate to **Protection > Array**.
- In the **Default Protection** panel, click the Edit (Set Default Protection) icon on the right of the appropriate row (the - row for the root of the array, or the row for a specific pod).
- In the **Available Protection Groups** column, select the protection groups to be added so they appear in the **Selected Protection Groups** column.
- Click **Set**.
- Navigate to **Protection > Protection Groups** and select your assigned default protection group.
- In the **SafeMode** pane, if the status is unlocked, click the edit icon and toggle the **Ratcheted** button to enabled (blue).

From the CLI:

- **Set the Default Protection List:** Define the default protection groups for the array root or a pod using the `purearray default-protection set` command.
- *Command Syntax (Array Root):* `purearray default-protection set --pgroup <PGROUP> ""`
- *Command Syntax (Pod):* `purearray default-protection set --pgroup <POD>::<<PGROUP> <POD>`
- *Example:* `purearray default-protection set --pgroup pod1::pg1 pod1`
- **Ratchet the Protection Group:** Ensure SafeMode is enabled on the default protection group to prevent manual eradication.
- *Command Syntax:* `purepgroup retention-lock ratchet <PGROUP>`

Default Value:

Initially, for new volumes not in a pod, the configuration of the root array default protection group list contains one protection group named pgroup-auto. When a new pod is created, its initial default protection group list is a copy of the root list, with the protection group names modified to include the pod name (e.g., pod1::pgroup-auto). These automatic protection groups start with a schedule that creates snapshots every 6 hours, replication disabled, retention lock ratcheted, and manual eradication disabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	11.2 <u>Perform Automated Backups</u> Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data.			

4.5 Ensure at least one encrypted array connection is configured for replication (Manual)

Profile Applicability:

- Level 1

Description:

FlashArray allows for connections to be created between any 2 FlashArrays for the purpose of replicating block and file data asynchronously, or block data synchronously. This allows for backups of data to be copied to other arrays, enabling disaster recovery.

FlashArray supports creating pods and using them to store file and block data to coordinate replication. Everpure recommends the following:

- Create at least one array connection.
- Encrypt all array connections.
- Ensure all peer arrays are on at least the same minor version, if not the same patch version.
- Add all file systems and directories to a pod with at least one replica link for backing up data.
- Add all volumes to either a pgroup with a replication schedule, a pod with at least one replica link for backing up data, or a stretched pod.

Rationale:

Backing up data to a secondary system is important for recovery in the case of disasters, as well as physical compromise that may render an array unusable. As such, Everpure recommends that there be at least one array peer utilized for backups.

Encrypting backup traffic in flight is crucial for ensuring backups of block and file data cannot be tampered with or have any sensitive contents exposed. Trust and privacy is established using TLS pre-shared keys with TLS1.3 in order to prevent interception of traffic.

While FlashArray does support replication between peers of different versions, some security features may only be available or effective when both arrays in an array connection are sufficiently new in version. Everpure recommends the following:

- Both arrays should be on 6.9.x. Ideally both are on the latest version of 6.9.x, or very close versions.
- All data on the array have at least one backup destination, regardless of whether it is file or block data.

Impact:

Enforcing encrypted array connections strictly requires the use of Ethernet (IP) transport, as Fibre Channel (FC) replication connections cannot be encrypted. Encrypting all replication traffic in flight introduces cryptographic processing overhead on the controllers of both the source and target arrays.

Furthermore, satisfying the requirement to replicate all volumes and file systems has significant environmental impacts. If you utilize ActiveCluster (synchronous replication via stretched pods), every host write must be synchronously acknowledged by the target array before completing, which intrinsically adds network round-trip latency to your front-end write I/O. If you utilize asynchronous or ActiveDR replication, retaining the replicated snapshots and continuous journal data will constantly consume physical storage capacity on the target array. Finally, maintaining the exact same Purity//FA version across peer arrays requires careful, staggered (one-at-a-time) upgrade orchestration to avoid causing an array outage during the update process.

Audit:

To align with the security recommendations, verify that at least one array connection exists for backups, that the replication transport utilizes Ethernet (IP) with encryption enabled, and that production volumes and file systems are assigned to a replicating pod or protection group.

From the GUI:

- Navigate to **Protection > Array**.
- In the **Connected Arrays** panel, verify that at least one remote array is listed and connected.
- Review the connection details in the panel and verify that the connection uses an Ethernet (IP) **Replication Transport** and that **Encryption** is enabled (or check the Encrypted toggle by clicking the menu icon and selecting Edit Connected Array).
- Navigate to **Storage > Volumes** and **Storage > File Systems**. Verify that the production objects belong to a Pod (that is stretched or has an ActiveDR replica link) or a Protection Group (with a replication schedule actively sending data to a target array).

From the CLI:

- Run the command `purearray connection list to view the status` and attributes of connected arrays.
- Review the output to ensure that a connection exists, the Transport is ip, and Encryption is set to encrypted.
- Run the `purevol list --protect` and `purefs list` commands to verify that all storage objects are associated with a replicating protection group or pod.

Remediation:

To align with the security recommendations, establish an encrypted array connection using an encrypted pre-shared key, and ensure your production data is actively replicating.

From the GUI:

- **Get the Connection Key:** Log in to the target array, navigate to **Protection > Array**, click the menu icon in the **Connected Arrays** panel, and select **Create Encrypted Connection Key**. Copy the key.
- **Connect the Arrays:** Log in to the source array, navigate to **Protection > Array**, click the menu icon in the **Connected Arrays** panel, and select **Connect Array**.
- Enter the target array's **Management Address**, select the **Type** (Async or Sync Replication), provide the **Encrypted Connection Key**, ensure **Replication Transport** is set to Ethernet (IP), and toggle **Encrypted** to enabled (blue). Click **Connect**.
- *(Optional - Encrypt an Existing Connection):* Click the menu icon for an existing connection and select **Edit Connected Array**, toggle **Encrypted** to enabled (blue), and click **Save**. You will be required to provide a newly generated encrypted connection key from the target array.
- **Protect the Data:** Navigate to **Storage > Volumes** or **Storage > File Systems** and assign your data to a pod or protection group configured for replication.

From the CLI:

- **Get the Encrypted Key:** On the target array, run the command `purearray list --connection-key --encrypted` to generate a one-time-use encrypted pre-shared key.
- **Connect the Arrays:** On the source array, run the `purearray connect` command with the `--encrypted` flag.
- **Command Syntax:** `purearray connect --management-address <IP_OR_FQDN> --type <async-replication|sync-replication> --encrypted`
- **Action:** Purity will prompt you interactively to paste the encrypted connection key.
- **Encrypt an Existing Connection:** If an unencrypted connection already exists, you can secure it using the `purearray connection enable` command.
- **Command Syntax:** `purearray connection enable --encrypted <ARRAY_NAME>`
- **Action:** Purity will prompt you interactively to paste a newly generated encrypted connection key from the target array.

Default Value:

By default, the FlashArray does not have any array connections configured. When an administrator connects two arrays without explicitly specifying encryption, the connection defaults to unencrypted. Volumes and file systems are not replicated to secondary arrays by default.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v8	11.4 <u>Establish and Maintain an Isolated Instance of Recovery Data</u> Establish and maintain an isolated instance of recovery data. Example implementations include, version controlling backup destinations through offline, cloud, or off-site systems or services.			

4.6 Ensure a snapshot offload target using HTTPS is configured when no array connection is available (Manual)

Profile Applicability:

- Level 2

Description:

FlashArray allows for connections to be created between a FlashArray and a generic offload target.

Offload targets allow snapshots to be stored externally to the array, with storage and transmission of proprietary-format snapshots via standardized 3rd party protocols.

Offload targets can either utilize the S3 data format, such as Amazon AWS, or the Azure blob format. This allows for backups of data to be copied to a 3rd party backup target, enabling disaster recovery.

This can be an alternative to array connections for backups if there is no secondary FlashArray available.

If no array connection can be created, Everpure recommends that you configure at least one offload target.

If an offload target is created, and a URI or endpoint is specified, Everpure recommends that it utilizes https.

Rationale:

Backing up data to a secondary system is important for recovery in the case of disasters, as well as physical compromise that may render an array unusable.

If backup to a secondary FlashArray is unavailable, backup to a 3rd party storage provider can be a reasonable alternative. Such backups should still be encrypted using https.

Impact:

Configuring a snapshot offload target requires the CloudSnap Purity//FA app to be installed on the array, which requires explicit intervention from Everpure Technical Services to deploy. Once configured, data transmitted to the offload target is stored unencrypted by the array, meaning administrators must strictly enforce server-side default encryption on their target S3 buckets or Azure Blob containers to ensure data-at-rest security. Additionally, unlike array-to-array replication, offload targets do not support the replication of hosts or host groups; administrators must specifically target the underlying volume members when building the protection group.

Audit:

To align with the security recommendations, verify that if an array connection cannot be created for replication, at least one snapshot offload target is configured, and that any custom URIs specified for the target strictly utilize HTTPS to encrypt data in flight.

From the GUI:

- Navigate to **Protection > Array**.
- Scroll to the **Offload Targets** panel and verify that at least one target is listed and its **Status** is connected.
- Review the **Details** column to verify that if a custom URI/endpoint is configured, it utilizes https://.

From the CLI:

- Run the command `pureoffload list to display all connected offload targets` and their general statuses.
- Run `pureoffload s3 list` or `pureoffload azure list` to display detailed connection settings.
- Review the output to ensure the connection exists and that any defined URI uses the https:// protocol rather than http://.

Remediation:

To align with the security recommendations, establish an offload target to act as a secondary backup repository and ensure secure transmission by enforcing HTTPS for any custom endpoints.

From the GUI:

- Navigate to **Protection > Array**.
- In the **Offload Targets** panel, click the **+** (connect) icon.
- In the Connect Offload Target window, select the **Protocol** (s3 or azure).
- **For Azure Blob:** Type a target **Name**, the Microsoft Azure **Account** name, the **Container** name, and the **Secret Access Key**.
- **For S3:** Type a target **Name**, the AWS **Access Key ID**, the **Bucket** name, and the **Secret Access Key**.
- If a custom endpoint/URI is required, ensure it begins with https://.
- If this is the first time a FlashArray is connecting to this specific bucket or container and it is currently empty, select the check box to **Initialize** the target.
- Click **Connect**.

From the CLI:

- **Connect to Azure Blob:** Connect the array to a Microsoft Azure Blob container using the `pureoffload azure connect` command. *(Note: Purity//FA will prompt you interactively to enter the secret access key twice).*
- **Command Syntax:** `pureoffload azure connect --account-name <ACCOUNT> --container-name <CONTAINER> <TARGET_NAME>`
- **Connect to S3:** Connect the array to an S3 bucket using the `pureoffload s3 connect` command. If using a custom URI, enforce HTTPS using the `--uri` flag. *(Note: Purity//FA will prompt you interactively to enter the secret access key twice).*
- **Command Syntax:** `pureoffload s3 connect --access-key-id <KEY_ID> --bucket <BUCKET> --uri https://<URI> <TARGET_NAME>`
- **Initialize the target (Optional):** Append the `--initialize` flag to either command if this is the first time the array is connecting to the empty Azure container or S3 bucket.

Default Value:

By default, the FlashArray does not have any offload targets connected or configured.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v8	11.4 <u>Establish and Maintain an Isolated Instance of Recovery Data</u> Establish and maintain an isolated instance of recovery data. Example implementations include, version controlling backup destinations through offline, cloud, or off-site systems or services.			

4.7 Ensure the health of array connections and offload targets is continuously monitored (Manual)

Profile Applicability:

- Level 1

Description:

Whether utilizing array connections or offload targets, FlashArray periodically monitors them for health issues that impact your ability to backup data.

Everpure recommends that you monitor the health of your array connections and offload targets, in order to detect unhealthy statuses.

Rationale:

Replication backups are crucial for security, and so verifying that replication connections are functional ensures non-disrupted data protection functionality.

Impact:

Continuously monitoring the health of array connections and offload targets requires configuring and maintaining external log forwarding (such as syslog, SNMP, or email alerts), which consumes network bandwidth and external storage capacity. When connections become unstable or degrade (entering a connecting or quarantined state), the array will automatically generate alerts that administrators or automated SIEM tools must actively process.

Audit:

To align with the security recommendations, verify that array connections, offload targets, and replication links are actively monitored to ensure they are healthy and fully functioning.

From the GUI:

- Navigate to **Protection > Array**.
- Review the **Connected Arrays** panel and verify that the **Status** column for peer arrays shows as connected rather than connecting or quarantined.
- Review the **Offload Targets** panel and verify that the **Status** column shows as connected rather than connecting, Scanning, or Not Connected.
- Navigate to **Protection > ActiveDR** and review the **Replica Links** pane to ensure no links display an unhealthy status.

From the CLI:

- Run the command `purearray connection list` to verify the status of peer array connections.
- Run the command `purepod replica-link list` to verify the status of ActiveDR connections.
- Run the command `pureoffload list` to display all connected offload targets.
- Review the outputs to ensure the paths are healthy and not displaying a connecting, quarantined, or unhealthy state.

Remediation:

Because this is a continuous monitoring procedure, remediation involves establishing regular manual or automated review processes to track connection metrics and respond to anomalies.

From the GUI (for manual monitoring):

- Navigate to **Protection > Array**.
- In the **Connected Arrays** panel, monitor the **Status** column. A status of connecting indicates an unhealthy connection (typically due to network issues), while quarantined indicates an unstable synchronous replication path that has been temporarily embargoed.
- In the **Offload Targets** panel, monitor the **Status** column. A status of connecting indicates an unhealthy network connection to the bucket/container, while Not Connected indicates the offload app itself is not running.
- Navigate to **Health > Alerts** to proactively review any generated alerts citing degraded connections or unhealthy paths.

From the CLI (for manual monitoring or scripted checks): Establish a scheduled process (such as a cron job via REST API or SSH) to periodically execute the following diagnostic commands:

- **Monitor Array Connections:** Run `purearray connection list` periodically. Investigate any paths that do not report a connected status.
- **Monitor Offload Targets:** Run `pureoffload list` periodically to ensure external storage targets are successfully reachable.
- **Monitor ActiveDR/ActiveCluster:** Run `purepod replica-link list` to check for unhealthy ActiveDR links, and `purepod list --mediator` to ensure the Pure1 Cloud Mediator is Online and not Unreachable.
- **Monitor Alerts:** Run `purealert list` to view recent system alerts regarding connectivity drops. *(Note: The **puremessage** command was deprecated in Purity//FA 6.8.0 and its functionality is now handled by **purealert**).*

Default Value:

By default, the FlashArray does not have any array connections or offload targets configured out of the box. When connections are configured, Purity//FA automatically generates warning or critical alerts if a replication connection degrades (such as transitioning to a connecting or quarantined state), but external monitoring of these statuses requires manual review or active syslog/SNMP integration.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.11 <u>Conduct Audit Log Reviews</u> Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.			

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	Identity and Access Management (IAM)		
1.1	Ensure a management SAML SSO configuration is created and enabled (Manual)	☐	☐
1.2	Ensure a management LDAP/Active Directory service is configured and enabled with at least one group mapped (Manual)	☐	☐
1.3	Ensure only authorized local administrative accounts exist and a local emergency-access account is retained (Manual)	☐	☐
1.4	Ensure administrators and directory groups are granted least-privilege roles via management access policies (Manual)	☐	☐
1.5	Ensure SSH key-based authentication is configured for CLI access, preferably sourced from LDAP (Manual)	☐	☐
1.6	Ensure brute-force lockout is set to 3 attempts with a lockout duration of at least 1 hour (Automated)	☐	☐
1.7	Ensure the password policy enforces 8+ characters, 3+ character groups, and username and dictionary checks (Automated)	☐	☐
1.8	Ensure OAuth API clients use least-privilege access policies and access-token TTLs of 60 minutes or less (Manual)	☐	☐
1.9	Ensure static REST API tokens are used only when necessary and configured to expire periodically (Manual)	☐	☐
1.10	Ensure administrative audit logs are forwarded to remote syslog or monitored via the REST API (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.11	Ensure administrative session logs are forwarded to remote syslog or monitored via the REST API (Manual)	☐	☐
1.12	Ensure system alerts are actively monitored via remote syslog or email alert watchers (Manual)	☐	☐
1.13	Ensure at least one alert watcher is configured to receive alerts of all severities (Automated)	☐	☐
1.14	Ensure at least one remote management syslog server is configured (Automated)	☐	☐
2	Environmental		
2.1	Ensure array TLS certificates are CA-signed, adequately sized, and rotated at least every 90 days (Manual)	☐	☐
2.2	Ensure SAML SSO uses HTTPS with encrypted assertions and signed requests (Manual)	☐	☐
2.3	Ensure Active Directory accounts are configured to require TLS (Manual)	☐	☐
2.4	Ensure LDAP directory services use LDAPS with a configured CA root of trust (Automated)	☐	☐
2.5	Ensure syslog servers use TLS with a configured CA root of trust (Automated)	☐	☐
2.6	Ensure the SMTP relay host is configured with STARTTLS encryption and authentication (Automated)	☐	☐
2.7	Ensure SNMP, if enabled, uses SNMPv3 with SHA authentication and AES privacy (Automated)	☐	☐
2.8	Ensure at least 3 NTP servers and an NTP symmetric key are configured (Automated)	☐	☐
2.9	Ensure product diagnostic tests for environmental integrations are run periodically (Manual)	☐	☐
3	Protocol		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
3.1	Ensure NFS export policies restrict client access and enforce secure authentication (no wildcards, root squash, no sys auth) (Automated)	☐	☐
3.2	Ensure SMB client policies require encryption, restrict client access, and disable anonymous access (Automated)	☐	☐
3.3	Ensure native Active Directory integration is used for NFS and SMB identity and authentication (Manual)	☐	☐
3.4	Ensure a hard-limit quota policy is enforced on the root managed directory of every file system (Automated)	☐	☐
3.5	Ensure space consumption and performance are monitored for anomalies (Manual)	☐	☐
3.6	Ensure SMB audit policies with syslog and file log targets are attached to production file systems (Manual)	☐	☐
4	Data Protection		
4.1	Ensure manual eradication is disabled and the eradication delay is at least 8 days for production data (Automated)	☐	☐
4.2	Ensure production volumes and hosts are protected by ratcheted (SafeMode) protection groups with daily snapshots (Manual)	☐	☐
4.3	Ensure an enabled snapshot policy taking at least one daily snapshot is attached to every directory (Automated)	☐	☐
4.4	Ensure default protection is configured at the array level and for every pod (Automated)	☐	☐
4.5	Ensure at least one encrypted array connection is configured for replication (Manual)	☐	☐
4.6	Ensure a snapshot offload target using HTTPS is configured when no array connection is available (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
4.7	Ensure the health of array connections and offload targets is continuously monitored (Manual)	☐	☐

Appendix: CIS Controls v8 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.3	Ensure only authorized local administrative accounts exist and a local emergency-access account is retained	☐	☐
1.5	Ensure SSH key-based authentication is configured for CLI access, preferably sourced from LDAP	☐	☐
1.7	Ensure the password policy enforces 8+ characters, 3+ character groups, and username and dictionary checks	☐	☐
1.8	Ensure OAuth API clients use least-privilege access policies and access-token TTLs of 60 minutes or less	☐	☐
1.9	Ensure static REST API tokens are used only when necessary and configured to expire periodically	☐	☐
1.10	Ensure administrative audit logs are forwarded to remote syslog or monitored via the REST API	☐	☐
1.11	Ensure administrative session logs are forwarded to remote syslog or monitored via the REST API	☐	☐
1.12	Ensure system alerts are actively monitored via remote syslog or email alert watchers	☐	☐
1.14	Ensure at least one remote management syslog server is configured	☐	☐
2.1	Ensure array TLS certificates are CA-signed, adequately sized, and rotated at least every 90 days	☐	☐
3.1	Ensure NFS export policies restrict client access and enforce secure authentication (no wildcards, root squash, no sys auth)	☐	☐
3.2	Ensure SMB client policies require encryption, restrict client access, and disable anonymous access	☐	☐
4.1	Ensure manual eradication is disabled and the eradication delay is at least 8 days for production data	☐	☐
4.2	Ensure production volumes and hosts are protected by ratcheted (SafeMode) protection groups with daily snapshots	☐	☐

Recommendation		Set Correctly	
		Yes	No
4.3	Ensure an enabled snapshot policy taking at least one daily snapshot is attached to every directory	☐	☐
4.4	Ensure default protection is configured at the array level and for every pod	☐	☐
4.5	Ensure at least one encrypted array connection is configured for replication	☐	☐
4.6	Ensure a snapshot offload target using HTTPS is configured when no array connection is available	☐	☐

Appendix: CIS Controls v8 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Ensure a management SAML SSO configuration is created and enabled	☐	☐
1.2	Ensure a management LDAP/Active Directory service is configured and enabled with at least one group mapped	☐	☐
1.3	Ensure only authorized local administrative accounts exist and a local emergency-access account is retained	☐	☐
1.5	Ensure SSH key-based authentication is configured for CLI access, preferably sourced from LDAP	☐	☐
1.7	Ensure the password policy enforces 8+ characters, 3+ character groups, and username and dictionary checks	☐	☐
1.8	Ensure OAuth API clients use least-privilege access policies and access-token TTLs of 60 minutes or less	☐	☐
1.9	Ensure static REST API tokens are used only when necessary and configured to expire periodically	☐	☐
1.10	Ensure administrative audit logs are forwarded to remote syslog or monitored via the REST API	☐	☐
1.11	Ensure administrative session logs are forwarded to remote syslog or monitored via the REST API	☐	☐
1.12	Ensure system alerts are actively monitored via remote syslog or email alert watchers	☐	☐
1.13	Ensure at least one alert watcher is configured to receive alerts of all severities	☐	☐
1.14	Ensure at least one remote management syslog server is configured	☐	☐
2.1	Ensure array TLS certificates are CA-signed, adequately sized, and rotated at least every 90 days	☐	☐
2.2	Ensure SAML SSO uses HTTPS with encrypted assertions and signed requests	☐	☐
2.3	Ensure Active Directory accounts are configured to require TLS	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.4	Ensure LDAP directory services use LDAPS with a configured CA root of trust	☐	☐
2.5	Ensure syslog servers use TLS with a configured CA root of trust	☐	☐
2.6	Ensure the SMTP relay host is configured with STARTTLS encryption and authentication	☐	☐
2.7	Ensure SNMP, if enabled, uses SNMPv3 with SHA authentication and AES privacy	☐	☐
2.8	Ensure at least 3 NTP servers and an NTP symmetric key are configured	☐	☐
3.1	Ensure NFS export policies restrict client access and enforce secure authentication (no wildcards, root squash, no sys auth)	☐	☐
3.2	Ensure SMB client policies require encryption, restrict client access, and disable anonymous access	☐	☐
3.3	Ensure native Active Directory integration is used for NFS and SMB identity and authentication	☐	☐
3.5	Ensure space consumption and performance are monitored for anomalies	☐	☐
3.6	Ensure SMB audit policies with syslog and file log targets are attached to production file systems	☐	☐
4.1	Ensure manual eradication is disabled and the eradication delay is at least 8 days for production data	☐	☐
4.2	Ensure production volumes and hosts are protected by ratcheted (SafeMode) protection groups with daily snapshots	☐	☐
4.3	Ensure an enabled snapshot policy taking at least one daily snapshot is attached to every directory	☐	☐
4.4	Ensure default protection is configured at the array level and for every pod	☐	☐
4.5	Ensure at least one encrypted array connection is configured for replication	☐	☐
4.6	Ensure a snapshot offload target using HTTPS is configured when no array connection is available	☐	☐
4.7	Ensure the health of array connections and offload targets is continuously monitored	☐	☐

Appendix: CIS Controls v8 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Ensure a management SAML SSO configuration is created and enabled	☐	☐
1.2	Ensure a management LDAP/Active Directory service is configured and enabled with at least one group mapped	☐	☐
1.3	Ensure only authorized local administrative accounts exist and a local emergency-access account is retained	☐	☐
1.4	Ensure administrators and directory groups are granted least-privilege roles via management access policies	☐	☐
1.5	Ensure SSH key-based authentication is configured for CLI access, preferably sourced from LDAP	☐	☐
1.7	Ensure the password policy enforces 8+ characters, 3+ character groups, and username and dictionary checks	☐	☐
1.8	Ensure OAuth API clients use least-privilege access policies and access-token TTLs of 60 minutes or less	☐	☐
1.9	Ensure static REST API tokens are used only when necessary and configured to expire periodically	☐	☐
1.10	Ensure administrative audit logs are forwarded to remote syslog or monitored via the REST API	☐	☐
1.11	Ensure administrative session logs are forwarded to remote syslog or monitored via the REST API	☐	☐
1.12	Ensure system alerts are actively monitored via remote syslog or email alert watchers	☐	☐
1.13	Ensure at least one alert watcher is configured to receive alerts of all severities	☐	☐
1.14	Ensure at least one remote management syslog server is configured	☐	☐
2.1	Ensure array TLS certificates are CA-signed, adequately sized, and rotated at least every 90 days	☐	☐
2.2	Ensure SAML SSO uses HTTPS with encrypted assertions and signed requests	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.3	Ensure Active Directory accounts are configured to require TLS	☐	☐
2.4	Ensure LDAP directory services use LDAPS with a configured CA root of trust	☐	☐
2.5	Ensure syslog servers use TLS with a configured CA root of trust	☐	☐
2.6	Ensure the SMTP relay host is configured with STARTTLS encryption and authentication	☐	☐
2.7	Ensure SNMP, if enabled, uses SNMPv3 with SHA authentication and AES privacy	☐	☐
2.8	Ensure at least 3 NTP servers and an NTP symmetric key are configured	☐	☐
3.1	Ensure NFS export policies restrict client access and enforce secure authentication (no wildcards, root squash, no sys auth)	☐	☐
3.2	Ensure SMB client policies require encryption, restrict client access, and disable anonymous access	☐	☐
3.3	Ensure native Active Directory integration is used for NFS and SMB identity and authentication	☐	☐
3.5	Ensure space consumption and performance are monitored for anomalies	☐	☐
3.6	Ensure SMB audit policies with syslog and file log targets are attached to production file systems	☐	☐
4.1	Ensure manual eradication is disabled and the eradication delay is at least 8 days for production data	☐	☐
4.2	Ensure production volumes and hosts are protected by ratcheted (SafeMode) protection groups with daily snapshots	☐	☐
4.3	Ensure an enabled snapshot policy taking at least one daily snapshot is attached to every directory	☐	☐
4.4	Ensure default protection is configured at the array level and for every pod	☐	☐
4.5	Ensure at least one encrypted array connection is configured for replication	☐	☐
4.6	Ensure a snapshot offload target using HTTPS is configured when no array connection is available	☐	☐

Recommendation		Set Correctly	
		Yes	No
4.7	Ensure the health of array connections and offload targets is continuously monitored	☐	☐

Appendix: CIS Controls v8 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
	No unmapped recommendations to CIS Controls v8	☐	☐

Appendix: Change History

Date	Version	Changes for this version
8/4/2026	1.0.0	Initial publication